Bilingual Study Guide · دليل دراسي ثنائي اللغة

Security in Computing — Essential Fundamentals and Exam Preparation

أمن الحاسوب: الأساسيات الجوهرية والتحضير للاختبار

Based on: Pfleeger et al., *Security in Computing*, 6th ed. (Pearson, 2024) — Chapters 1, 2, 3
as taught in the 2026 lecture slides (Dr. Abdulwasea Al-Azzani)

من الصفر إلى مستوى أسئلة الاختبار الجامعي · شرح مبسّط · أمثلة · طرق حلّ · أخطاء شائعة · تدريب مع إجابات · ورقة مراجعة سريعة

Table of Contents

كيف تستخدم هذا الدليل · How to Use This Guide 3

الصورة الكبرى في 5 دقائق · The Big Picture in 5 Minutes 4

الفصل الأول: المقدمة · Chapter 1 — Introduction 5

1.1 ما هو أمن الحاسوب · What is Computer Security? 5

1.2 الثغرة والتهديد والضابط · Vulnerability, Threat, Control 6

1.3 ثلاثية CIA وما حولها · The CIA Triad 7

1.4 أفعال الضرر الأربعة والهجمات السلبية والنشطة · Harm Acts & Attacks 9

1.5 التهديدات والمهاجمون والدوافع · Threats & Attackers 11

1.6 المخاطرة والتصنيف والطبقات · Risk, Classification, Layers 12

1.7 الضوابط والإجراءات المضادة · Controls 13

1.8 تدريب: الفصل الأول · Practice Chapter 1 16

الفصل الثاني: الأدوات — المصادقة والتحكم بالوصول والتشفير · Chapter 2 Toolbox 18

2.1 المصادقة · Authentication 18

2.1.1 كلمات المرور · Passwords 19

2.1.2 البيومترية والرموز المادية · Biometrics & Tokens 21

2.1.3 تدريب: المصادقة · Practice Authentication 23

2.2 التحكم بالوصول · Access Control 24

2.2.1 مراقب المرجع وهياكل التنفيذ · Reference Monitor & Structures 25

2.2.2 تدريب: التحكم بالوصول · Practice Access Control 28

2.3 التشفير · Cryptography 29

2.3.1 الشيفرات الكلاسيكية · Classical Ciphers 30

2.3.2 المتماثل وغير المتماثل والتدفقي والكتلي · Symmetric, Asymmetric, Stream, Block 31

2.3.3 خوارزميتا DES وAES · DES and AES 32

2.3.4 خوارزمية RSA · RSA 33

2.3.5 التجزئة والتواقيع والشهادات وتبادل المفاتيح · Hashes, Signatures, Certificates 34

2.3.6 تدريب: التشفير · Practice Cryptography 35

الفصل الثالث: البرامج والبرمجة · Chapter 3 — Programs & Programming 37

3.1 الخطأ والعيب والفشل وتصنيف العيوب · Error, Fault, Failure, Taxonomy 37

3.2 فيض المخزن المؤقت وهفوات البرمجة الأخرى · Buffer Overflows & Oversights 38

3.3 الوساطة غير المكتملة وTOCTTOU والأبواب الخلفية · Mediation, TOCTTOU, Trapdoors 40

3.4 الشيفرة الخبيثة · Malicious Code 40

3.5 الشيفرات الموجّهة والإجراءات المضادة · Targeted Code & Countermeasures 43

3.6 تدريب: الفصل الثالث · Practice Chapter 3 44

الأخطاء الشائعة وكيف تتجنبها · Common Mistakes 46

خريطة أسئلة الاختبارات السابقة · Exam Question Map 47

مواضيع قديمة خارج شرائح 2026 · Legacy Topics 48

ورقة المراجعة السريعة · Rapid Review Sheet 49

ترتيب الأولويات: الأساسي مقابل الثانوي · Priority Ranking 51

How to Use This Guide · كيف تستخدم هذا الدليل

Goal: take you from "I know nothing about computer security" to answering your professor's exam questions. Every idea is explained simply first (like to a smart child), then in exam language. Arabic and English terms sit side by side so you can answer in English on the exam.

الهدف: أن تنتقل من «لا أعرف شيئاً» إلى القدرة على حلّ أسئلة اختبار الدكتور. كل فكرة تُشرح أولاً ببساطة شديدة ثم بلغة الاختبار. المصطلحات الإنجليزية بجانب العربية لأن الإجابة في الاختبار تكون بالإنجليزية.

Scope & honest assumptions · النطاق والافتراضات

- Scope = **Chapters 1–3** of the textbook, exactly as covered by the 2026 lecture slides (395 slides): Ch.1 Introduction; Ch.2 Toolbox (Authentication, Access Control, Cryptography); Ch.3 Programs & Programming (flaws, malware).
- I did not have the textbook itself, so **I do not quote page numbers or text from it**. References like `S101` mean "lecture slide 101".
- Topics from older exams about operating-system memory protection (fence, paging, Kerberos…) are not in the 2026 slides — they are marked legacy .

النطاق = **الفصول 1–3** من كتاب Pfleeger كما وردت في شرائح 2026 (395 شريحة): الفصل 1 المقدمة؛ الفصل 2 الأدوات (المصادقة، التحكم بالوصول، التشفير)؛ الفصل 3 البرامج والبرمجة (العيوب والبرمجيات الخبيثة).

لم أطّلع على نص الكتاب نفسه، لذلك **لا أنقل أرقام صفحات ولا اقتباسات منه**. الرمز `S101` يعني «الشريحة 101».

مواضيع حماية الذاكرة ونظام التشغيل في الاختبارات القديمة (Fence, Paging, Kerberos…) ليست في شرائح 2026 وموسومة legacy .

Priority legend · مفتاح الأولويات

Tag	Meaning	المعنى
★★★ Essential · أساسي	Appeared in several past exams AND in the slides: learn first.	تكرر في الاختبارات ووجد في الشرائح: ابدأ به.
★★ Important · مهم	In slides / new MCQ bank; seen less often.	في الشرائح وبنك الأسئلة الجديد.
★ Supplementary · ثانوي	Background or rarely asked: only if time remains.	خلفية أو نادر السؤال: إن بقي وقت.

Fonts & layout note · ملاحظة الخطوط

English: Inter · Arabic: IBM Plex Sans Arabic (open-licence, embedded). Apple's SF Arabic is proprietary and cannot be legally embedded, so a similar clean humanist Arabic face was substituted.

الخط العربي المستخدم: IBM Plex Sans Arabic (مفتوح الترخيص ومضمَّن في الملف). خط SF Arabic من Apple غير مسموح بتضمينه قانونياً فاستُبدل بخط عربي نظيف مشابه.

الصورة الكبرى في 5 دقائق · The Big Picture in 5 Minutes

Imagine your **house**. It contains things you value (laptop, photos, money) — these are your **assets**. A window with a broken lock is a **vulnerability** (a weakness). A burglar who might use it is a **threat**. If the burglar actually climbs in and steals, that is an **attack** and what you lose is **harm**. A new lock, an alarm or a guard is a **control** (a protection). All of computer security is these six words.

تخيّل **بيتك**. فيه أشياء تقدّرها (حاسوب، صور، مال) وهي **الأصول** (assets). نافذة بقفل مكسور هي **ثغرة** (vulnerability) أي نقطة ضعف. واللصّ المحتمل الذي قد يستغلها هو **التهديد** (threat). إذا تسلّق فعلاً وسرق فهذا **هجوم** (attack) وما تخسره هو **الضرر** (harm). القفل الجديد أو الإنذار أو الحارس هو **ضابط/إجراء حماية** (control). أمن الحاسوب كله دوران حول هذه الكلمات الست.

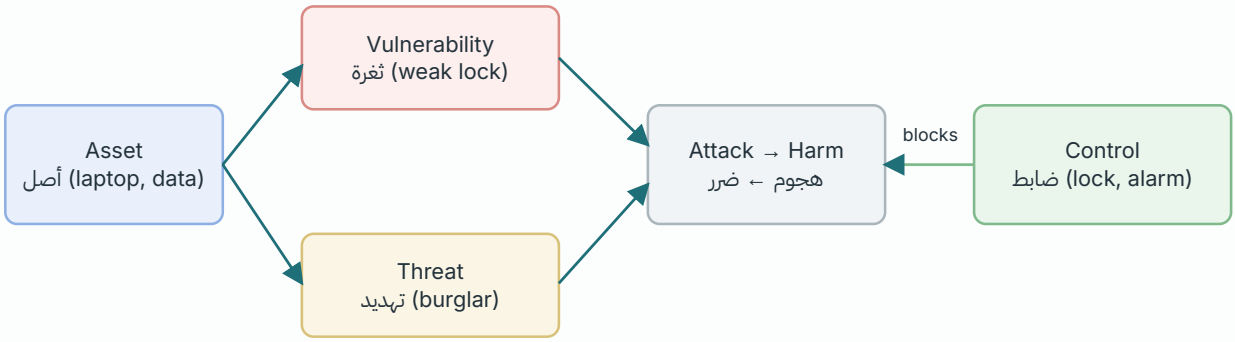


Figure: the six words of security · الكلمات الست

Tip · نصيحة

Exam habit: when a question gives a situation, name the **asset**, the **vulnerability**, the **threat**, and the **control**. That alone earns most of the marks.

عادة اختبارية: عند أي موقف اذكر: الأصل ثم الثغرة ثم التهديد ثم الضابط. هذا وحده يكسبك معظم الدرجات.

الفصل الأول: المقدمة · Chapter 1 — Introduction

1.1 ما هو أمن الحاسوب · What is Computer Security?

★★★ Essential · أساسي

Computer security = protecting the things you value (**assets**) of a computing system. A computing system is hardware, software, storage media, data and the people who use them. Assets types: **HW, SW, data, people, processes**, or combinations (S9).

أمن الحاسوب هو حماية الأشياء ذات القيمة (**الأصول**) في نظام الحاسوب. النظام = عتاد (HW) + برمجيات (SW) + وسائط تخزين + بيانات + أشخاص. أنواع الأصول: عتاد، برمجيات، بيانات، أشخاص، عمليات، أو مزيج منها.

Information security protects information in any form (paper, digital, spoken, in people's minds). **Cybersecurity** protects digital assets and networked systems; it is a part of information security. APTs and nation-state attacks belong almost exclusively to cybersecurity (S11–S13).

أمن المعلومات يحمي المعلومات بأي شكل (ورقي، رقمي، شفهي، في عقول الناس). أما **الأمن السيبراني** فيحمي الأصول الرقمية والأنظمة المتصلة بالشبكات، وهو جزء من أمن المعلومات. التهديدات المتقدمة المستمرة (APT) وهجمات الدول تنتمي تقريباً للأمن السيبراني فقط.

Definition · تعريف (S12)

Information security = protecting information and information systems from unauthorized *access, use, disclosure, disruption, modification, or destruction* in order to provide **integrity, confidentiality and availability**.

حماية المعلومات ونظمها من الوصول أو الاستخدام أو الإفصاح أو التعطيل أو التعديل أو الإتلاف غير المصرّح به، لتحقيق السلامة والسرية والتوافر.

Analogy · تشبيه

Principle of Easiest Penetration: a thief will not break a two-inch metal door if a window is open. The attacker uses *any* available means, so the weakest point is the most serious vulnerability (S15).

مبدأ أسهل اختراق: اللص لن يكسر باباً معدنياً سميكاً إذا كانت النافذة مفتوحة. المهاجم يستخدم أي وسيلة متاحة؛ لذا فنقطة الضعف الأضعف هي الأخطر. لا تفيد حماية الباب إن بقيت النافذة مفتوحة.

Common mistake · خطأ شائع

Do not say "cybersecurity = information security". Slides say they are often used interchangeably but cybersecurity is **a part of** information security (MCQ Q6).

لا تقل إنهما نفس الشيء: الأمن السيبراني **جزء** من أمن المعلومات (سؤال MCQ رقم 6).

1.2 الثغرة والتهديد والضابط · Vulnerability, Threat, Control

★★★ Essential · أساسي

Term	Simple meaning	Slide wording	المعنى بالعربية	Example
Vulnerability	a weakness	weakness in procedures, design or implementation that might be exploited to cause loss or harm (S16)	ثغرة: نقطة ضعف يمكن استغلالها	system does not verify user identity before access
Threat	something that could exploit it	a set of circumstances that has the potential to cause loss or harm / a condition that could exercise a vulnerability (S17)	تهديد: ظرف أو حالة قد تستغل الثغرة وتسبب ضرراً	hacker, flood, human error, HW/SW flaw
Control (countermeasure)	a protection	a protective measure — an action, device, procedure or technique — that removes or reduces a vulnerability (S18)	ضابط/إجراء مضاد: يزيل الثغرة أو يقلل أثرها	password, firewall, lock, policy
Attack	a threat becoming real	a malicious computer-security event carried out by an **attacker** (a human who exploits a vulnerability)	هجوم: تنفيذ فعلي للتهديد من مهاجم	phishing mail, DoS flood
Harm	the damage	negative consequence of an actualized threat (S62)	الضرر: النتيجة السلبية لتحقق التهديد	stolen laptop, lost file
Risk	chance of harm	the possibility for harm to occur (S63)	المخاطرة: احتمال وقوع الضرر	—

Relationship: a threat is blocked by a control of a vulnerability. **Incident = vulnerability + threat** (S88). Threat and vulnerability are *different things*: the threat is outside/inside the actor; the vulnerability is inside the system.

العلاقة: يُحجَب التهديدُ بوضع ضابط على الثغرة. **الحادثة (incident) = ثغرة + تهديد**. التهديد والثغرة شيئان مختلفان: الثغرة ضعف داخل النظام، والتهديد ما قد يستغل هذا الضعف.

Exam recipe: "differences between vulnerability, threats and control" (2016-17 Q4, 2017-18 Q4)

1) Define each in one sentence (table above). 2) Give one example each (door lock broken / burglar / new lock). 3) State the link: control blocks threat by fixing the vulnerability. 4) Add Fig. 1-4 idea: a threat is what *could* go wrong, a vulnerability is the *hole*, a control is the *patch*.

وصفة الإجابة: 1) عرّف كلاً منها بجملة. 2) مثال لكل واحد. 3) اذكر العلاقة: الضابط يمنع التهديد بسدّ الثغرة. 4) أضف: التهديد = ما قد يحدث، الثغرة = الفتحة، الضابط = الترقيع.

Extra terms: attack surface, CVE, CVSS, residual risk

Term	Meaning	المعنى
Attack surface	the system's full set of vulnerabilities — actual and potential (S70)	مجموع الثغرات الفعلية والمحتملة في النظام
CVE	Common Vulnerabilities and Exposures: a dictionary/list of publicly known vulnerabilities with common identifiers (S38)	قاموس لثغرات معروفة علناً بمعرّفات موحدة (يحدد *ما* هي الثغرة)
CVSS	Common Vulnerability Scoring System: standard way to score how harmful a vulnerability is (S38)	نظام معياري لتقدير مدى *خطورة* الثغرة (يعطي درجة)
Residual risk	risk left after controls are applied (S65)	الخطر المتبقي بعد تطبيق الضوابط

Common mistake · خطأ شائع

CVE ≠ CVSS. CVE **names/lists** vulnerabilities; CVSS **scores** their severity (MCQ Q47–49).

CVE تسمّي وتفهرس الثغرات، وCVSS تقيس خطورتها بدرجة. (MCQ 47–49)

1.3 ثلاثية CIA وما حولها · The CIA Triad

★★★ Essential · أساسي

Three goals of any secure system: **C**onfidentiality, **I**ntegrity, **A**vailability. Think of a school **diary**: only you may read it (confidentiality), nobody may secretly change it (integrity), and you must be able to open it when you need it (availability).

ثلاثة أهداف لأي نظام آمن: **السرية** (Confidentiality) و**السلامة** (Integrity) و**التوافر** (Availability). فكّر في **مذكرتك الخاصة**: لا يقرؤها إلا أنت (سرية)، ولا يغيّر فيها أحد خلسة (سلامة)، وتستطيع فتحها وقت الحاجة (توافر).

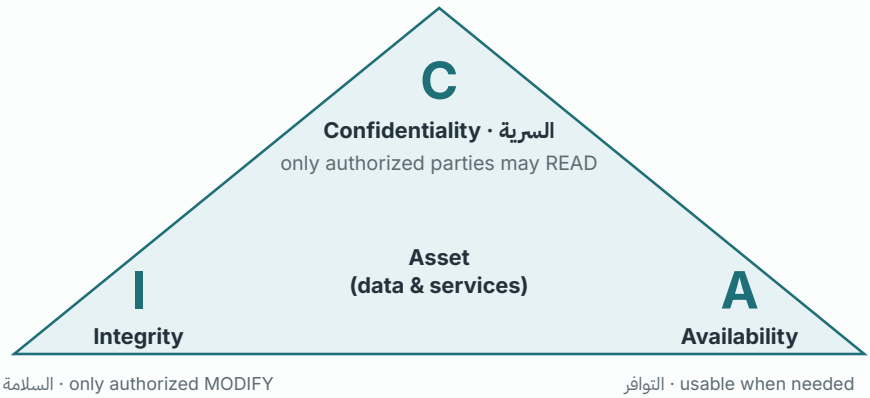


Figure: CIA triad (S20-S21)

Property	Means (slide wording)	Type of access	بالعربية
Confidentiality	asset viewed only by authorized parties (S21)	“read”: reading, viewing, printing	ألّا يطّلع على الأصل إلا المصرّح لهم
Integrity	asset modified only by authorized parties (S21)	“write”: change, change status, delete, create	ألّا يُعدَّل الأصل إلا بطرق وجهات مصرّح بها (دقيق، غير معدَّل، متّسق)
Availability	asset usable by authorized parties at appropriate times (S21)	timely response, fair allocation, fault tolerance, usability, controlled concurrency (S32)	إتاحة الأصل للمخوّلين في الوقت المناسب

More properties beyond CIA (S22–S23)

Property	Meaning	المعنى
Authentication	system can confirm the identity of a sender (ISO 7498-2)	التأكد من هوية المرسل
Nonrepudiation / accountability	sender cannot convincingly deny having sent something (ISO 7498-2)	عدم الإنكار: لا يستطيع المرسل إنكار إرساله
Auditability	ability to trace all actions related to an asset (US DoD)	إمكانية تتبّع كل الإجراءات المتعلقة بالأصل
Authorization	granting a subject access to an object after authentication, based on policy	منح الصلاحية بعد المصادقة وفق السياسة
Accounting	auditing/monitoring what a user does after access; creates an audit-trail log (S99)	تدقيق ما يفعله المستخدم وتسجيله في سجل تدقيق
Privacy	called the “fourth leg” of the CIA triad (S21)	الخصوصية: الركن الرابع بحسب الشريحة

Subject, Object, Mode, Policy (S29)

Subject = who (active entity: person, process). **Object** = what (passive resource: file, table). **Access mode** = how (read, write, execute…). **Policy** = Who + What + How — the rule that says which accesses are authorized.

> **الموضوع** (Subject) = من (كيان فعّال: شخص/عملية). **الكائن** (Object) = ماذا (مورد سلبي: ملف/جدول). **نمط الوصول** = كيف (قراءة/كتابة/تنفيذ). **السياسة** = من + ماذا + كيف.

"List some properties that could mean a failure of data confidentiality" (2016-17 Q2, 2017-18 Q2) — S28

1. An unauthorized **person** accesses a data item.
2. An unauthorized **process or program** accesses a data item.
3. An authorized person accesses **other data** he is not authorized for.
4. An unauthorized person accesses an **approximate** data value.
5. An unauthorized person learns the **existence** of a piece of data.

(1) شخص غير مصرّح يصل إلى عنصر بيانات.

(2) عملية/برنامج غير مصرّح يصل إلى عنصر بيانات.

(3) شخص مصرّح له ببيانات معيّنة يصل إلى بيانات أخرى غير مصرّح بها.

(4) شخص غير مصرّح يصل إلى قيمة تقريبية للبيانات.

(5) شخص غير مصرّح يعرف فقط بوجود بيانات معيّنة.

"Give an example..." CIA questions (all 3 exams with essays)

- **Confidentiality more important than integrity:** a patient's medical history or a secret military plan — once read by the wrong person the damage cannot be undone; a tiny typo matters less.
- **Integrity required but not confidentiality:** a published bus timetable / public stock price list — everyone may read it, but it must be correct.
- **Availability AND integrity more important than confidentiality:** hospital patient-monitoring or air-traffic control: wrong data or no data can kill; secrecy is secondary.
- **Availability overriding:** emergency (999/911) call system, power-grid control, ICU life support.
- **File with evidence of its own integrity and authenticity:** a digitally signed document: it carries a hash of its content (integrity) signed with the author's private key and a certificate (authenticity) — e.g. a signed PDF or a software update.

السرية أهم من السلامة: السجل الطبي أو خطة عسكرية سرية؛ كشفها لا يمكن تداركه بينما خطأ مطبعي بسيط أقل خطورة.

السلامة مطلوبة دون السرية: جدول رحلات أو أسعار أسهم منشورة؛ الجميع يقرؤها لكن يجب أن تكون صحيحة.

التوافر والسلامة أهم من السرية: مراقبة مرضى في مستشفى أو مراقبة الحركة الجوية: بيانات خاطئة أو غائبة قد تقتل.

التوافر هو الأهم: نظام الطوارئ، شبكة الكهرباء، أجهزة العناية المركزة.

ملف يحمل دليل سلامته وأصالته: وثيقة موقّعة رقمياً (تحوي تجزئة المحتوى موقّعة بالمفتاح الخاص + شهادة رقمية).

1.4 أفعال الضرر الأربعة والهجمات السلبية والنشطة · Harm Acts & Attacks

★★★ Essential · أساسي

Look at harm from the viewpoint of *what the attacker does*. Four acts: **Interception, Interruption, Modification, Fabrication**. Each one breaks a different CIA property. **Mnemonic** (follow the order of the slide): *Interception→Confidentiality, Interruption→Availability, Modification→Integrity, Fabrication→Authenticity/Integrity*.

انظر للضرر من زاوية *ماذا يفعل المهاجم*: أربعة أفعال: **الاعتراض** (Interception) و**الانقطاع/التعطيل** (Interruption) و**التعديل** (Modification) و**التلفيق** (Fabrication). كلٌّ منها يكسر خاصية مختلفة.

Act	What happens	Example	Breaks	بالعربية
Interception	unauthorized party gains access to an asset	illicit copying of files, wiretapping	**Confidentiality**	وصول طرف غير مخوّل (تنصّت/نسخ غير مشروع)
Interruption	asset lost, unavailable or unusable	destroying hardware, erasing a file, OS file-manager failure	**Availability**	فقدان الأصل أو تعطّله (إتلاف جهاز، حذف ملف، DoS)
Modification	unauthorized party tampers with an asset	changing database values, altering a program/transmitted data	**Integrity**	تعديل غير مصرّح به
Fabrication	unauthorized party creates counterfeit objects	adding spurious transactions or records	**Authenticity** (& integrity)	تلفيق عناصر مزيّفة

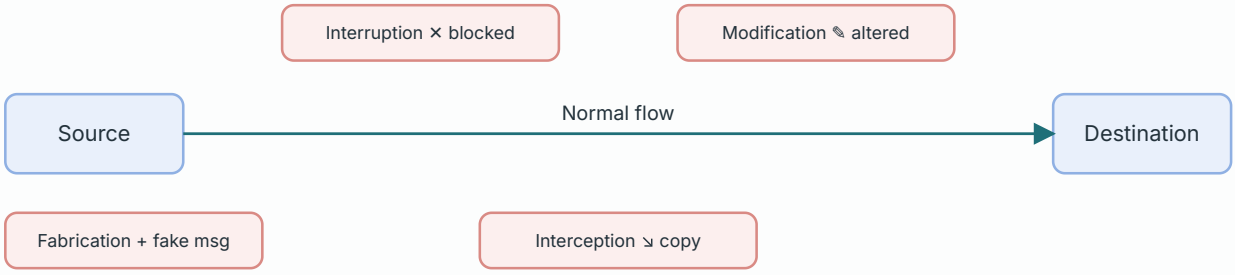


Figure (after S27): four acts on the flow between source and destination

Passive vs active attacks (S59–S60)

	Passive attack	Active attack
Threatens	**Confidentiality**	**Integrity, availability, authenticity**
Effect on system	does not modify data or harm the system	may change data or harm the system
Detection	difficult to detect, but easy to prevent (encryption)	easier to detect than to prevent
Examples	snooping (release of message content), traffic analysis	masquerading/impersonation, replay, alteration (modification), repudiation, denial of service (DoS)
بالعربية	سلبي: يهدد السرية ولا يغيّر البيانات، صعب الاكتشاف وسهل المنع بالتشفير	نشط: يهدد السلامة والتوافر والأصالة، ويغيّر البيانات، أسهل اكتشافاً من منعه

Common mistake · خطأ شائع

Traffic analysis is passive (even when messages are encrypted, who-talks-to-whom is observed). Replay and masquerade are **active**. Snooping ≠ Modification.

تحليل الحركة (Traffic analysis) هجوم سلبي. إعادة الإرسال (Replay) وانتحال الهوية (Masquerade) هجمات نشطة.

1.5 التهديدات والمهاجمون والدوافع · Threats & Attackers

★★ Important · مهم

Threats by **source**: **Nonhuman** (fire, flood, power loss, disk failure, wild animal) · **Human benign/nonmalicious** (spilling a drink, deleting a file by mistake, sending e-mail to the wrong person, typing 12 instead of 21) · **Human malicious** (impersonation, malicious code, hardware destruction) (S36).

التهديدات بحسب **المصدر**: **غير بشرية** (حريق، فيضان، انقطاع كهرباء، تعطل قرص) · **بشرية غير خبيثة** (سكب مشروب، حذف ملف خطأً، إرسال بريد للشخص الخطأ) · **بشرية خبيثة** (انتحال، شيفرة خبيثة، تدمير عتاد).

MCQ: "A power failure is a ... threat" → natural causes (nonhuman). "Malicious code on a general website" → human causes (malicious intent).

إجابات: انقطاع الكهرباء = أسباب طبيعية (غير بشري). الشيفرة الخبيثة على موقع = أسباب بشرية (نية خبيثة). (اختبارات 17-2016 و18-2017 سؤالا 11 و12)

Category	Detail (S47–S56)	بالعربية
External threats	from outside: physical, network, human (hackers), software, legal, social engineering	تهديدات من خارج المنظمة
Internal threats	employees, contractors, suppliers; studies say ≈80% of incidents come from insiders	تهديدات من الداخل (موظفون/مقاولون/موردون) ≈80% من الحوادث
...caused by weak security policies	unclassified data, unclear roles, no segregation of duties	سياسات ضعيفة: بيانات غير مصنّفة، أدوار غير واضحة، عدم فصل المهام
...weak security administration	weak/admin passwords, misconfiguration, unrestricted USB/remote access/downloads	إدارة أمنية ضعيفة: كلمات مرور ضعيفة، إعدادات خاطئة، وصول غير مقيّد
...lack of user awareness	sharing passwords, falling for phishing, ignoring clean-desk policy	قلة وعي المستخدم: مشاركة كلمات المرور، الوقوع في التصيد

Types of attackers (S43–S46)

Attacker	Motive / note	بالعربية
Individuals	fun, challenge, revenge	أفراد: التسلية أو التحدي أو الانتقام
Organized, worldwide groups	loosely connected groups (e.g. attacks on Estonia)	مجموعات منظمة عالمياً
Organized crime	profit; want to stay under the radar for a long time	الجريمة المنظمة: الربح والاستمرار دون كشف
Terrorists	use computers in 4 ways: as **targets** (DoS, defacement), **enablers** (websites, e-mail), **methods** of attack (Stuxnet), **enhancers** (propaganda, recruiting)	الإرهابيون: الحاسوب هدف/ممكِّن/وسيلة هجوم/معزِّز
Nation-state-sponsored	funded or directed by a government: espionage, sabotage, influence operations, economic/military advantage; high sophistication	هجمات مدعومة من دول: تجسس، تخريب، أفضلية اقتصادية/عسكرية
APT (advanced persistent threat)	organized, well-financed, patient attackers; long-term, **silent** campaigns; carefully chosen targets; **spear phishing**; often economic espionage	تهديد متقدم مستمر: طويل الأمد وصامت ومنظّم وممول

Method – Opportunity – Motive (S69) ★★★

A criminal needs three things. **Method** = the how (skills, knowledge, tools). **Opportunity** = the when (time and access). **Motive** = the why (a reason to attack this system). All three are necessary: **deny any one and the attack fails.** Analogy: a burglar needs a crowbar (method), an unlocked/unguarded house at night (opportunity), and a reason like money (motive).

الطريقة (Method) = كيف: مهارات ومعرفة وأدوات. **الفرصة** (Opportunity) = متى: وقت ووصول. **الدافع** (Motive) = لماذا: سبب مهاجمة هذا النظام. الثلاثة لازمة؛ **وإذا حرمتَ المهاجم من أحدها فشل الهجوم**. تشبيه: اللص يحتاج أداة (طريقة) وبيتاً غير محروس ليلاً (فرصة) وسبباً كالمال (دافع).

1.6 المخاطرة والتصنيف والطبقات · Risk, Classification, Layers

★★ Important · مهم

We cannot protect against everything, so we do **risk management**: (1) value the assets, (2) estimate harm from each threat, (3) compute cost of protection, (4) choose safeguards by degree of risk and budget, (5) apply them to maximize harm averted. Risk left over = **residual risk**. Difficulty: value and impact are hard to measure (S66–S68).

لا يمكن حماية كل شيء فنقوم بـ**إدارة المخاطر**: (1) تقدير قيمة الأصول (2) تقدير الضرر من كل تهديد (3) حساب كلفة الحماية (4) اختيار الضوابط بحسب درجة الخطر والموارد (5) تطبيقها لتقليل الضرر. ما يبقى بلا تغطية = **الخطر المتبقي**. الصعوبة: يصعب قياس القيمة والأثر بدقة.

Scheme	Labels (low → high)	Used by
Business	Public · Sensitive · Private · Confidential	companies
Military	Unclassified · (SBU) · Confidential · Secret · Top Secret	military/government
Traffic Light Protocol	White · Green · Amber · Red	cross-sector sharing

Layers of information security (S76): physical, hardware, network, communications, software, human/personnel — all supported by policies, procedures and processes. **Classification steps** (S72): define levels → criteria → data owners → custodian → controls per level → exceptions → transfer → periodic review → declassify → awareness.

طبقات الأمن: المادي، العتاد، الشبكة، الاتصالات، البرمجيات، العنصر البشري؛ وتدعمها السياسات والإجراءات. **خطوات التصنيف**: تحديد المستويات والمعايير والمالكين والأمين (custodian) والضوابط لكل مستوى والاستثناءات والمراجعة الدورية.

Tip · نصيحة

Data roles (S151): **owner** = ultimate responsibility, sets classification; **custodian** = enforces policies (IT); **user** = day-to-day access, follows policy.

أدوار البيانات: المالك (المسؤول الأعلى ويحدد التصنيف)، الأمين (ينفّذ السياسات)، المستخدم (يلتزم بها).

1.7 الضوابط والإجراءات المضادة · Controls

★★★ Essential · أساسي

To protect against harm we **neutralize the threat, close the vulnerability, or both**. Six ways to deal with harm (S80): **Prevent** (block the attack / close the hole), **Deter** (make attack harder but not impossible), **Deflect** (make another target more attractive, e.g. honeypot), **Mitigate** (make impact less severe), **Detect** (as it happens or later), **Recover** (get back to normal).

للحماية نعطّل التهديد أو نسدّ الثغرة أو كليهما. ست طرق للتعامل مع الضرر: **المنع** (Prevent) و**الردع** (Deter: يجعل الهجوم أصعب لا مستحيلاً) و**التحويل** (Deflect: جعل هدف آخر أكثر جاذبية مثل Honeypot) و**التخفيف** (Mitigate) و**الكشف** (Detect) و**التعافي** (Recover).

Castle analogy · تشبيه القلعة (S82)

A medieval castle: strong gate (prevent), moat and drawbridge (control access), arrow slits (defend), guards who check people (detect), a plan to repair walls (recover). Real security uses **several layers together**.

قلعة قديمة: بوابة قوية (منع)، خندق وجسر متحرك (التحكم بالدخول)، حرّاس يفحصون القادمين (كشف)، خطة لإصلاح الأسوار (تعافٍ). الأمن الحقيقي يجمع عدة طبقات معاً.

Three classes of controls (S84–S85)

Class	What it is	Examples	بالعربية
Physical	tangible thing that stops or blocks an attack	walls, fences, locks, human guards, sprinklers/fire extinguishers	ضوابط مادية: أسوار، أقفال، حراس، مطافئ
Procedural / Administrative	a command or agreement telling people how to act	laws, regulations, policies, procedures, guidelines, copyrights, patents, contracts	إجرائية/إدارية: قوانين، سياسات، إجراءات، عقود
Technical	technology (HW or SW)	passwords, OS/app access control, encryption, network protocols, firewalls, IDS/IPS	تقنية: كلمات مرور، تشفير، جدران نارية

Common mistake · خطأ شائع

"Laws and regulations" = **procedural/administrative** (appeared in all 4 exams!). A **firewall** = technical. A **fence** = physical. A **security policy** = administrative.

القوانين والأنظمة = ضوابط إجرائية/إدارية (ظهر السؤال في الاختبارات الأربعة). الجدار الناري = تقني. السور = مادي. السياسة = إدارية.

Defense in depth = overlapping controls: more than one control or more than one class, because none is always best (S86). **Effectiveness of controls** increases with: **awareness of the problem**, **likelihood of use** (controls people actually use), **overlapping controls**, and **periodic review** (MCQ 2016-17 Q15 → answer "a & c"... see note in the solved bank).

الدفاع في العمق = ضوابط متداخلة (أكثر من ضابط أو أكثر من فئة). تزداد **فعالية الضوابط** بـ: الوعي بالمشكلة، احتمال الاستخدام، تداخل الضوابط، والمراجعة الدورية.

NIST/ENISA five functions (S81)

Function	Meaning	بالعربية
Identify	understand organization to minimize risk	التعرّف
Protect	safeguards limiting impact	الحماية
Detect	identify that an event occurred	الكشف
Respond	act after learning of an event	الاستجابة
Recover	resilience & timely repair	التعافي

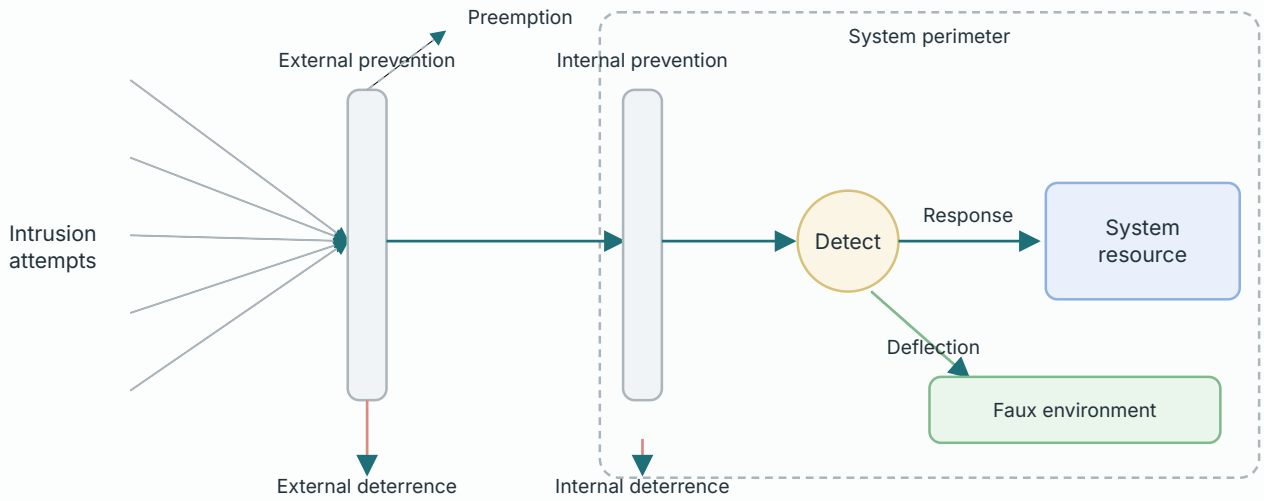
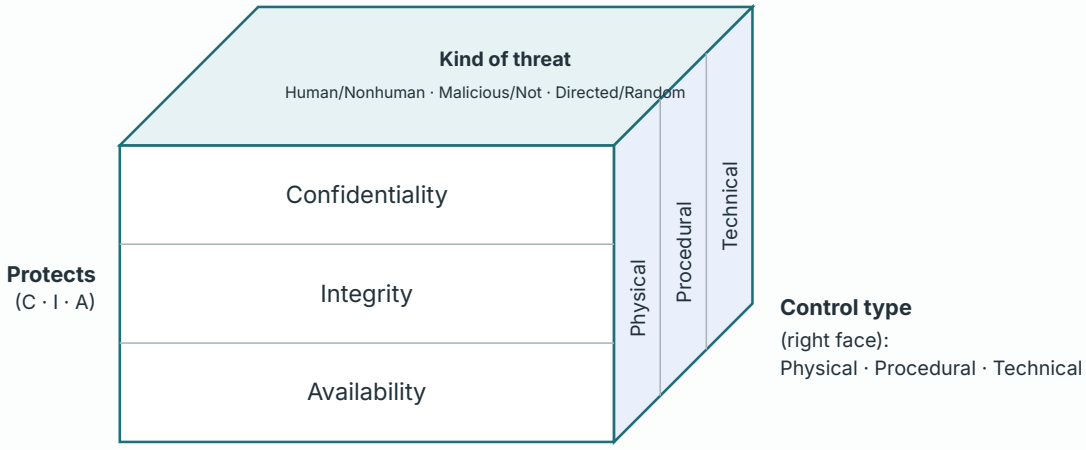


Figure 1-12 (S83), redrawn: effects of controls — prevention, deterrence, deflection, detection, response



"Types of Countermeasures" cube (S85): each countermeasure protects C, I or A, against a kind of threat, using a physical, procedural or technical control

Exam recipe: "List the countermeasures with examples for each, and draw the figure" (2016-17 Q7, 2017-18 Q5)

1. List the 6 ways: prevent (firewall/locks), deter (warning banners, legal penalties), deflect (honeypot), mitigate (backups/redundancy), detect (IDS, audit logs, guards), recover (restore from backup, incident response).
2. List 3 classes: physical, procedural/administrative, technical — with 2–3 examples each.
3. Draw **Figure 1-12** (flow of intrusion attempts through external/internal prevention, detection, response, deflection) or the cube above. Label every part.

(1) اذكر الطرق الست مع مثال لكل طريقة (جدار ناري، عقوبات قانونية، Honeypot، نسخ احتياطي، IDS وسجلات، استعادة النسخ).

(2) اذكر الفئات الثلاث مع أمثلة.

(3) ارسم الشكل 12-1 أو المكعب أعلاه مع تسمية كل جزء.

1.8 تدريب: الفصل الأول · Practice Chapter 1

Q1. Someone copies a confidential file without leaving a trace. Which harm act and which CIA property?

A. Interruption – Availability
B. Interception – Confidentiality
C. Modification – Integrity
D. Fabrication – Authenticity

Answer: B

Copying/reading without authorization is interception; it hurts confidentiality (S25).

النسخ/الاطلاع غير المصرّح اعتراض (Interception) ويمسّ السرية.

Q2. A weak password policy is best described as a ...

A. threat
B. vulnerability
C. control
D. harm

Answer: B

A weakness that can be exploited is a vulnerability; the attacker would be the threat.

نقطة ضعف = ثغرة؛ المهاجم هو التهديد.

Q3. Which statement about passive attacks is correct?

A. They modify data
B. They threaten availability
C. They are hard to detect but easy to prevent by encryption
D. They are easier to detect than prevent

Answer: C

Passive = confidentiality threat, no modification; encryption prevents reading (S59).

الهجوم السلبي صعب الاكتشاف وسهل المنع بالتشفير.

Q4. A company hires a guard, writes a security policy and installs a firewall. Which three classes of controls?

A. Physical, procedural, technical
B. Technical, technical, physical
C. Procedural, physical, technical
D. Preventive, detective, corrective

Answer: A

Guard = physical, policy = procedural/administrative, firewall = technical (listed in this order in the stem, so A).

الحارس مادي، السياسة إجرائية، الجدار الناري تقني.

Q5. What does “deny method, opportunity or motive” achieve?

A. Nothing, all three are optional
B. The attack fails because all three are necessary
C. It increases residual risk
D. It guarantees perfect security

Answer: B

Method, opportunity and motive are all necessary for an attack to succeed (S69).

الثلاثة لازمة لنجاح الهجوم؛ حرمان أحدها يُفشله.

Q6. Honeypots mainly illustrate which way of dealing with harm?

A. Prevent
B. Deflect
C. Recover
D. Mitigate

Answer: B

A honeypot makes another target more attractive: deflection (S80).

Honeypot = تحويل الهجوم (Deflect).

الفصل الثاني: الأدوات — المصادقة والتحكم بالوصول والتشفير · Chapter 2 Toolbox

Security people use three main tools again and again: **authentication** (who are you?), **access control** (what may you do?) and **cryptography** (hide/seal the data). This chapter teaches them in that order.

يستخدم المختصون ثلاث أدوات أساسية: **المصادقة** (من أنت؟) و**التحكم بالوصول** (ماذا يُسمح لك؟) و**التشفير** (إخفاء البيانات وختمها). سنتعلمها بهذا الترتيب.

2.1 المصادقة · Authentication

★★★ Essential · أساسي

Identification = claiming who you are (saying your name / user ID). **Authentication** = proving the claim is true (password, card, fingerprint). **Authorization** = what you are allowed to do after you are authenticated. **Accounting** = recording what you did. Order: **Identification** → **Authentication** → **Authorization (→ Accounting)** (MCQ Q361).

الهوية (Identification) = ادّعاء من أنت (اسمك/معرّف المستخدم). **المصادقة** (Authentication) = إثبات صحة الادعاء (كلمة مرور/بطاقة/بصمة). **التفويض** (Authorization) = ما يُسمح لك به بعد المصادقة. **المحاسبة** (Accounting) = تسجيل ما فعلت. الترتيب: هوية ← مصادقة ← تفويض (← محاسبة).

Analogy · تشبيه

At the school gate you say "I'm Ali" (identification). The guard checks your student card (authentication). The card says you may enter the library but not the staff room (authorization). The guard writes your entry time in a book (accounting).

عند بوابة المدرسة تقول «أنا علي» (هوية). الحارس يفحص بطاقتك (مصادقة). البطاقة تسمح لك بالمكتبة لا بغرفة المعلمين (تفويض). ويسجّل وقت دخولك في دفتر (محاسبة).

	Identification	Authentication
Is it ...	asserting who a person is (S93)	proving that the asserted identity is correct (S93)
Protected?	**Not** secret: well known, public, guessable (name, e-mail, account number)	**Private** and protected (password, card, fingerprint)
Gives real protection?	No — anyone can type a name	Yes — it is the technical measure that stops unauthorized individuals/processes entering
بالعربية	الهوية معلنة وغير محمية ولا توفّر حماية حقيقية	المصادقة سرية ومحمية وتمنع غير المصرّح لهم

Exam: "Compare between identification and authentication" (2016-17 Q3A, 2017-18 Q3A, 2018-19 Q1A)

Write the table above in 4–5 lines: definition, protected or not, examples, and the order (identify first, then authenticate).

اكتب الجدول أعلاه بـ4–5 أسطر: التعريف، الحماية، الأمثلة، الترتيب.

The “something you…” factors (S95–S96)

Factor	Meaning	Examples	بالعربية
Something you KNOW	secret in your head	password, PIN, **passphrase**, mother’s maiden name, secret handshake	شيء تعرفه
Something you HAVE	physical object (a **token**)	ID badge, physical key, driver’s licence, magnetic-stripe/chip card, smart card	شيء تملكه
Something you ARE	body characteristic = **biometrics**	fingerprint, iris, retina, face, hand geometry, vein pattern	شيء أنت عليه (خصائص حيوية)
Something you DO	behaviour (slides list it as a 4th quality)	voice pattern, handwriting, typing rhythm, signature	شيء تفعله

In the exam · في الاختبار

Fingerprint = “something you are” (also “biological identification/authentication”): in the 2016-17 option list the right answer is *b & d*. **Passphrase** = know. **Identity badge** = have. **Bank card + PIN** = have + know (two forms combined). **Voice pattern** = a behaviour/biometric; when “something you do” is absent from the options pick *what you are*.

البصمة = شيء أنت عليه. عبارة المرور = ما تعرفه. شارة الهوية = ما تملكه. البطاقة + PIN = ما تملك + ما تعرف. نمط الصوت = سلوك حيوي (يُختار «what you are» إن لم يُذكر «تفعل»).

2.1.1 كلمات المرور · Passwords

★★★ Essential · أساسي

Passwords are the oldest form of computer authentication. They have **four difficulties** (S101): **Use** (typing one for every access is inconvenient), **Disclosure** (if you reveal it, the object is exposed; changing it forces telling all legitimate users), **Revocation** (to remove one user you must change the password for everybody), **Loss** (a forgotten password may be unrecoverable).

لكلمات المرور **أربع صعوبات**: **الاستخدام** (إدخالها في كل وصول مزعج) و**الإفشاء** (إذا كُشفت صار الكائن مكشوفاً) و**الإلغاء** (لسحب صلاحية شخص يجب تغيير الكلمة للجميع) و**الفقدان** (قد يتعذر استرجاعها). في أسئلة الاختيار: «Revocation and use» و«Disclosure and loss» كلتاهما صحيحة → الإجابة «a & b».

Attacking passwords (S102–S112)

Five approaches: **dictionary attack** (try words from lists), **inferring** passwords likely for a user (name, birthday, pets), **guessing probable passwords** (123456, password), **defeating concealment** (steal the password table), **exhaustive/brute-force** (try all combinations).

خمسة أساليب: هجوم القاموس، استنتاج كلمة المرور المحتملة للمستخدم، تخمين كلمات المرور الشائعة، كسر الإخفاء (سرقة جدول كلمات المرور)، والبحث الشامل (Brute force).

"What are the password guessing steps?" (2017-18 Q3B "P.70"; 2018-19 Q1B; 2016-17 Q3B) — the 12-step list (S103–S104)

1. No password
2. Same as the user ID
3. The user's name or derived from it
4. Common word list plus common names and patterns
5. Contained in a short college dictionary
6. A complete English word list
7. Common non-English dictionaries
8. Short college dictionary with capitalizations/substitutions
9. Complete English dictionary with capitalizations/substitutions
10. Common non-English dictionaries with capitalization/substitution
11. Brute force: all combinations of **alphabetic** characters
12. Brute force: all combinations from the **full character set**

اكتبها بالترتيب: (1) بلا كلمة مرور (2) نفس اسم المستخدم (3) اسم المستخدم أو مشتق منه (4) قائمة كلمات وأسماء شائعة (5–7) قواميس: كلية قصير، إنجليزي كامل، لغات أخرى (8–10) القواميس نفسها مع تغيير الحروف الكبيرة والاستبدالات (11) القوة الغاشمة بالحروف فقط (12) القوة الغاشمة بكل المحارف.

Protecting passwords. The system stores a **one-way concealed** form (hash), never the plain password: converting is easy, reversing is effectively impossible. A **rainbow table** is a precomputed list of hashes of common passwords; if two users have the same hash they likely chose the same common password. A **salt** — an extra per-user value joined to the password before hashing — makes identical passwords hash differently so rainbow tables fail. **Account lockout** after a few failed attempts limits online guessing.

حماية كلمات المرور: يخزّن النظام شكلاً مُخفىً أحادي الاتجاه (تجزئة) لا الكلمة نفسها: التحويل سهل والعكس شبه مستحيل. **جدول قوس القزح** قائمة تجزئات محسوبة مسبقاً للكلمات الشائعة. **الملح** (Salt) قيمة إضافية لكل مستخدم تُضاف قبل التجزئة فتجعل نفس الكلمة تعطي تجزئات مختلفة. **قفل الحساب** بعد محاولات فاشلة يحد من التخمين.

"What are the criteria to choose good passwords?" (2017-18 Q3C "P.78"; 2016-17, 2018-19) — S115–S117

- Use characters beyond a–z: upper & lower case, digits, symbols.
- Be **long** (≥12; slide says "at least 15" in one place; more is better).
- Avoid real names/words (family, pets, characters) and dictionary words (also foreign), and avoid prepending/appending a digit.
- Avoid keyboard patterns (QWERTY, 123) and personal data (SSN, plate, phone).
- Must not contain blanks; begin with a letter (per slide).
- Change regularly; use variants for different systems.
- Do not write it down; do not tell anyone.
- Easy to remember → use a **passphrase** (first letters of a private phrase).

استخدم أحرفاً كبيرة وصغيرة وأرقاماً ورموزاً.

اجعلها طويلة (12 فأكثر).

تجنب الأسماء والكلمات القاموسية وإضافة رقم لكلمة.

تجنب أنماط لوحة المفاتيح والمعلومات الشخصية.

لا فراغات، وابدأ بحرف.

غيّرها دورياً واستخدم صيغاً مختلفة للأنظمة.

لا تكتبها ولا تخبر أحداً.

سهلة التذكر عبر عبارة المرور (Passphrase).

Sample password policy (S113–S114)

Expire every 60 days · ≥12 characters · lowercase+uppercase+digits+special · differ by ≥3 chars from old · not reuse last 24 · no names/dictionary words · change at most once per 24 h.

تنتهي صلاحيتها كل 60 يوماً، 12 محرفاً على الأقل، مزيج من أنواع المحارف، تختلف 3 محارف عن القديمة، لا تكرر آخر 24، لا أسماء، تغيير مرة كل 24 ساعة.

2.1.2 البيومترية والرموز المادية · Biometrics & Tokens

★★★ Essential · أساسي

Biometrics = authentication by biological properties ("something you are"): fingerprint, voice, face, hand geometry, retina/iris, handwriting, typing, vein patterns. **Advantages:** cannot be lost, stolen, forgotten or shared; always available; hard to forge. **Problems:** relatively new/intrusive; devices are costly; reader can be a single point of failure; match is not exact (sampling + a threshold); speed limits accuracy; physical traits change with day/age; forgeries are possible; reliable for authentication but much less for identification.

البيومترية = المصادقة بالخصائص الحيوية. **المزايا:** لا تُفقد ولا تُسرق ولا تُنسى ولا تُشارك، متوفرة دائماً، يصعب تزويرها.

المشاكل: حديثة ومزعجة لبعض الناس، أجهزتها مكلفة، القارئ نقطة فشل وحيدة، المطابقة غير دقيقة تماماً (عتبة قبول)، السرعة تحدّ الدقة، الصفات تتغير بمرور الزمن، إمكانية التزوير، وموثوقة للمصادقة أكثر من التعريف.

Error	Meaning	Mnemonic	بالعربية
False positive (false accept)	accepts a wrong person (authenticator does not match but is accepted)	dangerous: lets intruder in	قبول خاطئ
False negative (false reject)	rejects the right person	annoying: blocks the real user	رفض خاطئ

Common mistake · خطأ شائع

Reducing false positives usually increases false negatives, and vice versa. Usually a false negative is less serious than a false positive.

تقليل أحدهما يزيد الآخر عادةً؛ والرفض الخاطئ أقل خطراً غالباً من القبول الخاطئ.

Tokens — something you have (S125–S129)

Type	Meaning	Example
Passive token	does nothing, contents never change	photo ID, key
Active token	takes action / can change or communicate	transport card that rewrites balance; wireless token
Static token	value stays fixed (easy to copy; vulnerable to **skimming**)	keys, ID cards, magnetic-stripe cards, RFID
Dynamic token	value changes (one-time pass number): useful for remote authentication	RSA SecurID: changes on time / button / challenge

Skimming = using a device to secretly copy authentication data and relay it to an attacker. **Federated identity management** = a union of separate identification/authentication systems: one profile, one authentication, in one place; the other systems trust it. **Single sign-on (SSO)**: log in once per session and an umbrella procedure passes your credentials to each service.

Skimming: نسخ بيانات المصادقة خلسة. **إدارة الهوية الاتحادية** (Federated identity) = اتحاد أنظمة تعريف ومصادقة منفصلة: ملف تعريف واحد ومصادقة واحدة في مكان واحد وتثق بها بقية الأنظمة. **الدخول الأحادي** (SSO): تسجّل دخولك مرة واحدة في الجلسة ويمرّر النظام بياناتك لكل خدمة.

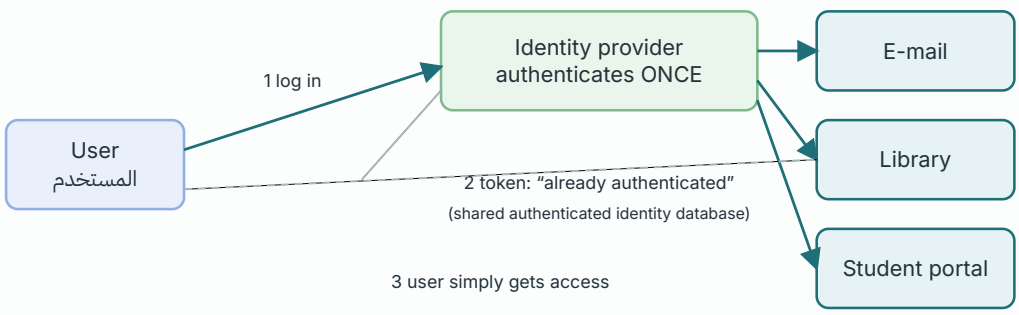


Figure: federated identity / single sign-on (drawn for "describe a federated identity management scheme with a figure", 2016-17 Q3E)

Multifactor authentication (MFA/2FA) = combine different categories (e.g. password + fingerprint, or card + PIN). Two passwords are not MFA (same category). It also costs more inconvenience and

management. Contextual factors can help: **time and location** (e.g. accountant allowed 8:00–17:00 from the office terminal).

المصادقة متعددة العوامل = الجمع بين فئات مختلفة (كلمة مرور + بصمة). كلمتا مرور لا تُعدّان MFA لأنهما من الفئة نفسها.
ويمكن استخدام **الزمان والمكان** كعامل إضافي. المصادقة القوية (Strong authentication) = استخدام طريقتين مختلفتين على الأقل.

MCQ: "Strong authentication ..." → requires at least two different authentication methods (2015-16 Q3).

الإجابة: تتطلب طريقتين مصادقة مختلفتين على الأقل (وليست مجرد كلمة مرور طويلة).

2.1.3 تدريب: المصادقة · Practice Authentication

Q1. Typing your username into a login box is ...

A. authentication
B. identification
C. authorization
D. accounting

Answer: B

You are only *claiming* an identity.

أنت فقط تدّعي الهوية.

Q2. Which pair is NOT multifactor?

A. Password + fingerprint
B. Card + PIN
C. Password + security question
D. Token + face

Answer: C

Both are "something you know".

كلاهما من نوع «ما تعرفه».

Q3. A salt in password storage mainly prevents ...

A. brute force on one account
B. rainbow-table/identical-hash attacks
C. shoulder surfing
D. skimming

Answer: B

Per-user salt makes equal passwords produce different stored values.

الملح يجعل الكلمات المتطابقة تعطي تجزئات مختلفة.

Q4. A fingerprint reader accepts an impostor. This is a ...

A. false negative
B. false positive
C. salt failure
D. replay

Answer: B

False accept = false positive.

قبول خاطئ = إيجابي خاطئ.

Q5. Which token changes its value each use?

A. magnetic-stripe card
B. RFID badge
C. SecurID token
D. physical key

Answer: C

Dynamic token.

الرمز الديناميكي.

2.2 التحكم بالوصول · Access Control

★★★ Essential · أساسي

Access control = allowing all and only authorized accesses. Basic paradigm: a **subject** is permitted to access an **object** in a particular **mode**, and only such accesses are allowed. Subjects = users/processes; objects = files, tables, programs, memory, devices, network connections (even users, since the OS can act on them); modes = read, write, modify, delete, execute, create, destroy, copy... (S142).

التحكم بالوصول = السماح بكل الوصولات المصرّح بها وحدها. النموذج الأساسي: يُسمح لـ**موضوع** (Subject) بالوصول إلى **كائن** (Object) بنمط معيّن (Mode)، ولا يُسمح بسواه. أنماط الوصول: قراءة، كتابة، تعديل، حذف، تنفيذ، إنشاء، نسخ...

Good practice (S145–S150): **Least privilege** (give the smallest number of objects needed), **verify acceptable usage** (not just "can access?" but "is this operation legitimate?", e.g. only push/pop on a stack), **check every access**, track/revisit policy, choose **granularity** (fineness; finer = more decisions = slower), keep an **access log** (audit trail), **limited privilege** (management concept).

ممارسات جيدة: أقل صلاحية، التحقق من الاستخدام المقبول، فحص كل وصول، مراجعة السياسة دورياً، اختيار الدقة (Granularity)، الاحتفاظ بسجل وصول، والصلاحية المحدودة.

Principle	Question it answers	MCQ trick (2015-16 Q33/34)
Enforce least privilege	not allowing access to unnecessary objects guards against weaknesses if part of the protection fails	Q33 → **enforce least privilege**
Verify acceptable usage	are accesses performed legitimate object accesses?	Q34 → **verify acceptable usage**
Check every access	is every single access checked?	—

Four access-control models (S152–S160)

Model	Who decides?	Key idea	Used in	بالعربية
DAC Discretionary	the **object owner**	owner chooses who gets access; implemented with ACLs	Windows, Linux, macOS, most Unix	تقديري: المالك يقرر
MAC Mandatory	the **system/policy** via **security labels**	users get clearance (Secret/Top Secret); users cannot change permissions; strict, costly	military/government; SELinux, Trusted Solaris	إلزامي: النظام يقرر عبر التصنيفات
RBAC Role-based	the **role**/job function	permissions attach to roles (Accountant, Manager), users get roles; great for staff turnover	companies/universities	قائم على الأدوار
ABAC Attribute-based	**attributes** of subject, object, environment	policy like “department=HR AND classification=low AND time=work-hours”; very granular	modern flexible systems	قائم على الخصائص

Security model (S193)	Primary focus
Bell–LaPadula	Confidentiality (government/defence)
Biba	Data integrity
Clark–Wilson	Integrity / well-formed transactions (banking, ERP)
Brewer–Nash	Conflict of interest (consulting, finance)
Graham–Denning	Secure creation/deletion of subjects & objects
Harrison–Ruzzo–Ullman	Formal analysis/safety of access policies

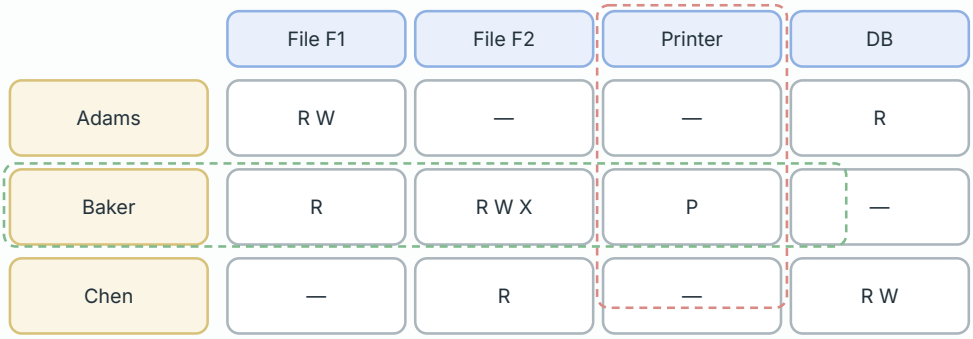
2.2.1 مراقب المرجع وهياكل التنفيذ · Reference Monitor & Structures

★★★ Essential · أساسي

Reference monitor (James Anderson): a concept (not a product) for hardware+software that controls access. Three properties: **always invoked** (checks every access), **tamperproof / unbypassable** (cannot be bypassed or altered), **verifiable** (small and simple enough to be sure it is correct). “Always invoked” + “unbypassable” give **complete mediation**.

مراقب المرجع (Reference Monitor): مفهوم لتجهيزات وبرمجيات تتحكم بالوصول، وله ثلاث خصائص: **يُستدعى دائماً** (يفحص كل وصول)، **محصّن ضد العبث/لا يمكن تجاوزه**، و**قابل للتحقق** (صغير وبسيط بما يكفي للثقة بصحته).

The access control matrix and its slices



Red dashed = a COLUMN (one object) → Access Control List (ACL)
Green dashed = a ROW (one subject) → privilege list / directory / capabilities

Figure: access control matrix (rows = subjects, columns = objects, cells = rights)

Structure	Slice of the matrix	Who keeps it?	Strength	Weakness	بالعربية
Access Control Directory (ACD)	a **list per subject** (a directory of files that user may access); user cannot write in it	OS	easy to implement	list too long for shared objects; revocation is slow (search every directory) and rights may be propagated; **pseudonyms** → multiple inconsistent permissions	قائمة لكل مستخدم
Access Control Matrix (ACM)	whole table; **sparse** because most subjects have no access to most objects; stored as triples <subject, object, rights>	OS	clear model	searching triples is inefficient; seldom used directly	المصفوفة (متناثرة)
Access Control List (ACL)	**one list per object** showing all subjects who may access it and their rights; Unix uses (user, group, world); Multics user–group–compartment with wildcards	OS	easy to see who has access to an object; easy to revoke per object	hard to list everything one user can access	قائمة لكل كائن
Privilege list	a **row** of the matrix for a subject	OS	easy revocation when a user is removed	—	قائمة صلاحيات
Capability	an **unforgeable token/ticket** giving the holder rights to an object (essentially a compressed row)	OS holds it for the user (pointer) or encrypted capability; can be created **only by a specific request from a user to the OS**	can be passed to subprocedures with fewer rights; domain of a process	must be unforgeable; revocation is harder	قدرة/تذكرة غير قابلة للتزوير
Procedure-oriented AC	a procedure forms a capsule around the object; users must call it (add user/delete user/check user)	trusted procedure	implements **information hiding**; fine-grained	inefficient: no fast direct access	حماية موجّهة بالإجراءات
RBAC	privileges attached to **roles/groups**	OS/apps	simplifies administration	—	حسب الدور

Exam: “Compare the access control directory and the access control list” (2016-17 Q5B)

ACD (Directory)	ACL
one list **per subject**	one list **per object**
shows what a user can access	shows who can access an object
revocation hard (search all directories); list grows with shared objects; pseudonym problem	revocation easy per object; but listing a user’s rights is harder

ACD: قائمة لكل مستخدم (موضوع) تبيّن ما يصل إليه؛ سحب صلاحية كائن صعب (يجب البحث في كل الأدلة) ومشكلة الأسماء المستعارة. ACL: قائمة لكل كائن تبيّن من يصل إليه؛ أسهل في سحب صلاحيات الكائن.

Exam: “What are the models of how access rights can be maintained and implemented by the reference monitor?” (2016-17 Q5A)

Answer with the list on slide 165: **Access Control Directory, Access Control Matrix (and its subsets: ACL and Privilege List), Capability, Procedure-Oriented Access Control, Role-Based Access Control** — one line each (table above).

الإجابة هي القائمة الواردة في الشريحة 165: Directory، Matrix (وفروعها ACL وPrivilege list)، Capability، Procedure-oriented، RBAC — مع سطر شرح لكل منها.

Common mistake · خطأ شائع

Do not confuse: **ACL = per object**; **directory/capability list = per subject**. “In the directory, a list is created for each subject.” (2015-16 Q30; 2018-19 Q26)

لا تخلط: ACL لكل كائن؛ Directory/Capability لكل موضوع.

2.2.2 تدريب: التحكم بالوصول · Practice Access Control

Q1. In which model does the file owner decide who can read the file?

A. MAC
B. DAC
C. RBAC
D. Bell–LaPadula

Answer: B

Discretionary = owner’s discretion.

التقديري = حسب تقدير المالك.

Q2. A bank gives permissions by job titles such as Teller and Manager. Model?

A. DAC
B. MAC
C. RBAC
D. ABAC

Answer: C

Permissions attach to roles.

الصلاحيات مرتبطة بالأدوار.

Q3. The access control matrix is sparse because ...

A. all subjects can access all objects
B. most subjects have no access rights to most objects
C. it has no rows
D. it stores only capabilities

Answer: B

So storing the whole table wastes space; lists/capabilities store only non-empty cells.

لذلك نخزن الخانات غير الفارغة فقط.

Q4. A ticket that can only be created by an OS request and cannot be forged is a ...

A. ACL
B. capability
C. directory
D. role

Answer: B

Capability (S183).

القدرة Capability.

Q5. Which three properties define a reference monitor?

A. Always invoked, tamperproof, verifiable
B. Fast, cheap, small
C. Public, private, secret
D. Read, write, execute

Answer: A

Always invoked/unbypassable/small-and-verifiable.

يُستدعى دائماً، محصّن، قابل للتحقق.

2.3 التشفير · Cryptography

★★★ Essential · أساسي

Cryptography = hiding the meaning of a message by transforming it so only the right person can read it. Simple idea: you write a note to a friend in a **secret code** that only you two know. Words to know: **plaintext** (original readable message), **ciphertext** (scrambled message), **encryption** (plaintext → ciphertext), **decryption** (ciphertext → plaintext), **key** (the secret value that controls the transformation), **cryptosystem** (system that performs encryption and decryption: algorithm + keys), **cryptographer** (works for the sender/receiver), **cryptanalyst** (tries to break messages), **cryptology** = cryptography + cryptanalysis (S202–S211).

التشفير = إخفاء معنى الرسالة بتحويلها بحيث لا يقرؤها إلا المقصود. الفكرة البسيطة: تكتب لصديقك رسالة بـ«رمز سري» لا يعرفه غيركما. المصطلحات: **النص الصريح** (Plaintext) و**النص المشفّر** (Ciphertext) و**التشفير** (Encryption) و**فك التشفير** (Decryption) و**المفتاح** (Key) و**نظام التشفير** (Cryptosystem) و**المشفِّر** (Cryptographer) و**محلل التشفير**: يحاول كسر الرسائل) و**علم التشفير الشامل** (Cryptology = التشفير + تحليله).

Common mistake · خطأ شائع

Cryptography hides the *meaning*; **steganography** hides the *existence* of the message (MCQ Q116–117). **Cryptology** = both cryptography and cryptanalysis (Q113).

التشفير يُخفي المعنى، والإخفاء (Steganography) يخفي وجود الرسالة نفسها.

Notation: `C = E(K, P)` and `P = D(K, C)`. Strength of a cipher is judged by the **work factor** (effort to break) — never rely on keeping the algorithm secret; the key must be secret. **Brute force** = try every possible key. **Confusion** (hide the relation between key and ciphertext, achieved by **substitution**) and **diffusion** (spread one plaintext bit over many ciphertext bits, achieved by **transposition**) — Shannon (S276).

الرمز: C = E(K,P) وP = D(K,C). قوة الشيفرة تُقاس بـ**عامل العمل** (جهد الكسر). **الغموض** (Confusion) يخفي العلاقة بين المفتاح والنص المشفر ويتحقق بـ**الاستبدال**، و**الانتشار** (Diffusion) ينشر أثر البت الواحد على كثير من البتات ويتحقق بـ**التبديل (Transposition)**.

2.3.1 الشيفرات الكلاسيكية · Classical Ciphers

★★ Important · مهم

Cipher	Kind	How it works	بالعربية
Caesar	substitution (mono-alphabetic)	shift each letter by k (k=3: A→D). `C=(P+k) mod 26`	إزاحة كل حرف k مواضع
Monoalphabetic	substitution	any permutation of the alphabet; easy to break by letter frequency	استبدال بأي ترتيب؛ يُكسر بتحليل التكرار
Playfair	substitution (digraph)	5×5 key matrix; encrypts **pairs** of letters	أزواج الحروف، مصفوفة 5×5
Hill	substitution	uses **matrix** multiplication (Lester Hill)	عمليات مصفوفات
Vigenère	polyalphabetic substitution	a **keyword** controls a series of Caesar shifts	كلمة مفتاحية تتحكم بسلسلة إزاحات
Vernam / One-Time Pad	substitution/XOR	random key as long as the message, used **once** → perfect secrecy; hard key distribution	مفتاح عشوائي بطول الرسالة يُستخدم مرة واحدة
Rail Fence	transposition	write letters in a **zigzag** over rows, read row by row	نمط متعرج
Row/Columnar transposition	transposition (block)	write in rows, read by columns in key order	قراءة بالأعمدة

Worked example · مثال محلول (Caesar, k=3)

Plaintext `MEET ME AFTER THE TOGA PARTY` → ciphertext `PHHW PH DIWHU WKH WRJD SDUWB` (S229). M→P, E→H, T→W. To decrypt, shift back by 3.

M→P وE→H وT→W... لفك التشفير نرجع 3 مواضع.

Worked example · Rail Fence depth 2

"HELLO WORLD" → rows: H L O O L (positions 1,3,5,7,9) and E L W R D → ciphertext `HLOOLELWRD`.

نكتب الحروف متناوبة على سطرين ثم نقرأ السطر الأول ثم الثاني.

Product cipher: apply two ciphers in sequence, e.g. `C = E2(E1(P, k1), k2)` (2016-17 Q7 → **product cipher**).

الشيفرة المركّبة (Product): تطبيق شيفرتين متتاليتين مثل C=E2(E1(P,k1),k2).

2.3.2 · المتماثل وغير المتماثل والتدفقي والكتلي
Symmetric, Asymmetric, Stream, Block

★★★ Essential · أساسي

Symmetric (secret-key): one key encrypts and decrypts (like one house key used by both of you). Fast, good for big data; problem = **key distribution**: *n* users need `n(n−1)/2` keys. **Asymmetric** (public-key): each user has two keys, **public** (shared) and **private** (secret); what one encrypts the other decrypts (like a mailbox: anyone can drop a letter in, only the owner has the key to open). *n* users need `2n` keys. Slow (≈10,000× slower).

المتماثل: مفتاح واحد للتشفير وفكه؛ سريع ومناسب للبيانات الكبيرة؛ مشكلته توزيع المفاتيح: لـ n مستخدماً نحتاج n(n−1)/2 مفتاحاً. **غير المتماثل:** لكل مستخدم مفتاحان: عام وخاص؛ ما يشفّره أحدهما يفكّه الآخر (كصندوق بريد: يضع أي شخص رسالة ولا يفتحه إلا صاحبه). لـ n مستخدماً نحتاج 2n مفتاحاً. بطيء (≈10000 مرة).

Characteristic	Symmetric	Asymmetric	بالعربية
Number of keys	1	2 (public + private)	عدد المفاتيح
Key size	56–112 (DES) · 128–256 (AES)	1000–2000 bits	حجم المفتاح
Key secrecy	shared secret	one secret (private), one public	سرية المفتاح
Basis	substitution + permutation, rounds	mathematical functions (number theory)	الأساس
Best uses	bulk data confidentiality/integrity	authentication, digital signatures, key exchange	الاستخدامات
Key distribution	out-of-band needed	public key can distribute other keys	التوزيع
Keys for n people	n(n−1)/2	2n	المفاتيح لـ n
Speed	fast	slow (≈10,000× slower)	السرعة

Calculation · حسابات

Symmetric keys for 10 users = 10×9/2 = **45**; asymmetric = 2×10 = **20**. For 100 users: 4950 vs 200.

10 مستخدمين: 45 مفتاحاً متماثلاً مقابل 20 غير متماثل. لـ100 مستخدم: 4950 مقابل 200.

Exam: "What are the differences between stream and block ciphers?" (2016-17 Q8C, 2017-18 Q6C, 2018-19 Q6B) — S265–S269

	Stream	Block
Encrypts	each bit/byte separately (e.g. Caesar)	a group (block) of symbols together (e.g. columnar transposition, DES, AES)
Advantages	**Speed** of transformation (no waiting for other symbols); **low error propagation** (error affects one symbol)	**High diffusion** (one ciphertext block depends on many plaintext symbols); **immunity to insertion** of symbols
Disadvantages	**Low diffusion**; susceptible to malicious insertions/modifications	**Slow** (must wait for a full block); **error propagation** within the block; **padding** of the last short block

الشيفرة التدفقية تشفّر كل بت/بايت على حدة: سريعة وخطؤها لا ينتشر لكن انتشارها ضعيف وعرضة للإدراج والتعديل الخبيث.
الكتلية تشفّر كتلة من الرموز معاً: انتشار عالٍ ومناعة ضد إدراج رموز لكنها أبطأ وينتشر الخطأ داخل الكتلة وتحتاج حشواً (Padding) للكتلة الأخيرة.

2.3.3 خوارزميتا DES وAES · DES and AES

★★★ Essential · أساسي

Property	DES	AES (Rijndael)
Date	1976 (IBM, NIST/NBS)	selected 2001 (FIPS 197)
Type	symmetric **block** cipher	symmetric **block** cipher
Block size	64 bits	128 bits
Key length	64 bits (56 effective; 8 are check bits)	128, 192 or 256 bits
Rounds (cycles)	16	10 / 12 / 14 for 128 / 192 / 256-bit keys
Primitives	substitution + permutation (confusion & diffusion)	substitution, shift, XOR (bit mixing)
Design	open design, closed rationale; developed by IBM, enhanced by NSA	Dutch inventors Vincent Rijmen & Joan Daemen; open process
Security today	weak: 56-bit key too short for brute force	strong; no known significant attack

AES round — 4 steps (S283): **1. Byte substitution (SubBytes)** — replace each byte using an S-box (confusion). **2. Shift rows (ShiftRows)** — a transposition: row *n* is rotated left (n−1) bytes (diffusion). **3. Mix columns (MixColumns)** — mixes bytes within each column (confusion + diffusion). **4. Add round key (AddRoundKey)** — XOR with a subkey unique to the round. Last round omits MixColumns in the standard design (not required for the exam).

جولة AES — 4 خطوات: (1) استبدال البايتات (SubBytes) عبر جدول S-box (غموض). (2) إزاحة الصفوف (ShiftRows): الصف n يُزاح (n−1) بايتاً لليسار (انتشار). (3) خلط الأعمدة (MixColumns) (غموض وانتشار). (4) إضافة مفتاح الجولة (AddRoundKey) بعملية XOR.

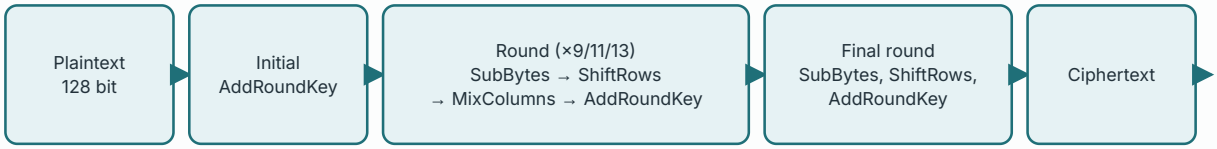


Figure: AES outline (128-bit key: 10 rounds) · مخطط AES

Exam: "In brief, explain the AES algorithm" (2016-17 Q8A, 2017-18 Q6A) — 6-point model answer

1) AES = Advanced Encryption Standard, selected by NIST (2001) to replace DES. 2) Symmetric block cipher: 128-bit blocks. 3) Key sizes 128/192/256 bits → 10/12/14 rounds. 4) Each round: byte substitution, shift rows, mix columns, add round key. 5) Substitution gives confusion; shift/mix give diffusion. 6) Fast, simple on small processors, designed by Rijmen & Daemen with open public review; no known significant attack.

1) AES معيار التشفير المتقدم اختاره NIST عام 2001 بديلاً لـ DES. 2) شيفرة كتلية متماثلة بكتل 128 بت. 3) مفاتيح 128/192/256 بت وجولات 10/12/14. 4) كل جولة: استبدال بايت، إزاحة صفوف، خلط أعمدة، إضافة مفتاح. 5) الاستبدال يعطي غموضاً والباقي انتشاراً. 6) سريعة ومبنية على أسس رياضية قوية وبلا شبهة ثغرة خفية.

2.3.4 خوارزمية RSA · RSA

★★★ Essential · أساسي

RSA (Rivest–Shamir–Adelman, 1978) is a public-key system based on **number theory**: multiplying two big primes is easy, but factoring the product back is very hard. Encrypt `C = P^e mod n`; decrypt `P = C^d mod n`. Keys can be applied in either order: encrypting with the private key and decrypting with the public key proves who sent it (basis of digital signatures).

RSA خوارزمية مفتاح عام مبنية على نظرية الأعداد: ضرب عددين أوليين كبيرين سهل وتحليل الناتج صعب جداً. التشفير C = P^e mod n وفكه P = C^d mod n. يمكن تطبيق المفتاحين بأي ترتيب: التشفير بالمفتاح الخاص وفكه بالعام يثبت هوية المرسل (أساس التوقيع الرقمي).

RSA key setup (2016-17 Q8B; 2017-18 Q6B; 2018-19 Q6A) — 7 steps (S297–S298)

1. Choose two large primes **p, q** (p=17, q=11).
2. Compute **n = p·q** = 187.
3. Compute **φ(n) = (p−1)(q−1)** = 16·10 = 160.
4. Choose **e** with 1<e<φ(n) and gcd(e, φ(n)) = 1: e = 7.
5. Compute **d** with e·d ≡ 1 (mod φ(n)): 7·23 = 161 = 160+1 → d = 23.
6. **Public key PU = {e, n} = {7, 187}**.
7. **Private key PR = {d, n} = {23, 187}** (keep secret).

Encrypt M = 88: C = 88^7 mod 187 = **11**. Decrypt: 11^{23} mod 187 = **88**.

اختر أوليين p وq، احسب n=p·q وφ(p)=(p−1)(q−1)، اختر e أولياً مع φ(n)، احسب d بحيث e·d ≡ 1 mod φ(n). المفتاح العام {e,n} والخاص {d,n}. مثال: p=17,q=11 → n=187, e=7, d=23=φ. تشفير M=88 يعطي C=11 وفكه يعيد 88.

Calculate by hand · حساب يدوي مختصر

$88^7 \bmod 187$: $88^2 = 7744 \bmod 187 = 77$ (187×41=7667; 7744−7667=77); $88^4 = 77^2 = 5929 \bmod 187 = 132$ (187×31=5797); $88^7 = 88^4 \cdot 88^2 \cdot 88 = 132 \cdot 77 \cdot 88 \bmod 187$. 132·77=10164 mod 187 = 66 (187×54=10098); 66·88=5808 mod 187 = **11** (187×31=5797) ✓.

نكرر التربيع مع الباقي كل مرة (Square-and-multiply) فلا نتعامل مع أعداد ضخمة.

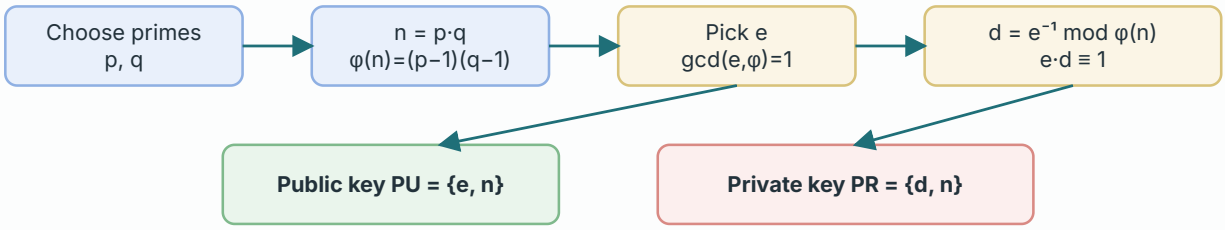


Figure: RSA key setup (“illustrate the RSA key setup”, 2016-17 Q8B)

2.3.5 · التجزئة والتواقيع والشهادات وتبادل المفاتيح
Hashes, Signatures, Certificates

★★★ Essential · أساسي

Cryptographic hash function (checksum/message digest): turns any-size input into a fixed-size **digest**; one-way; any 1-bit change alters the digest — so it **seals** a file to detect change. **MD4/MD5** (Rivest) → **128-bit** digest (MD5 is an improved MD4); **SHA/SHS** → **160-bit** digest (S305). MD5 is no longer considered secure (collisions found).

دالة التجزئة: تحوّل أي مدخل إلى ملخص (Digest) ثابت الطول، أحادية الاتجاه؛ تغيير بت واحد يغيّر الناتج فتكشف أي تعديل. MD4/MD5 تنتج 128 بت؛ SHA/SHS تنتج 160 بت. MD5 لم تعد آمنة.

Digital signature (DS): a file + proof it has not changed + who signed + validation that it is the signer’s + link to the file. Properties: **unforgeable, authentic, not alterable, not reusable**. Method: hash the message, then encrypt the hash with the sender’s private key; the receiver decrypts with the sender’s public key and compares hashes. It gives **authenticity, integrity, non-repudiation**, but not confidentiality by itself.

التوقيع الرقمي: ملف + دليل عدم تعديله + هوية الموقّع + تحقق أنه توقيعه + ربط التوقيع بالملف. خصائصه: غير قابل للتزوير، أصيل، غير قابل للتعديل، غير قابل لإعادة الاستخدام. الطريقة: تجزئة الرسالة ثم تشفير التجزئة بالمفتاح الخاص للمرسل؛ يفكّه المستلم بالمفتاح العام ويقارن. يوفّر الأصالة والسلامة وعدم الإنكار لكن لا يوفّر السرية وحده.

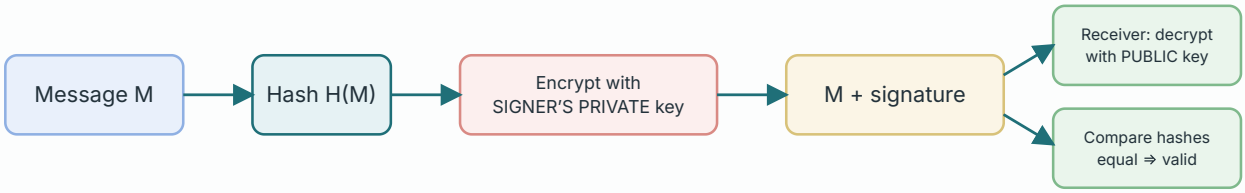


Figure: digital signature process (S313–S314)

Concept	Meaning	بالعربية
Digital certificate	binds an identity to a **public key**, signed by a **Certificate Authority (CA)** that vouches for the binding (S316)	شهادة رقمية تربط الهوية بالمفتاح العام وتوقّعها جهة موثوقة (CA)
Key exchange (public-key)	S sends `E(kPUB-R, E(kPRIV-S, K))`: inner lockbox proves it is from S, outer lockbox only R can open (S307–S309)	تبادل المفتاح المتماثل بتشفير مزدوج: توقيع المرسل وتشفير للمستلم
Diffie–Hellman	S and R agree on public n and g; each picks a secret (s, r); send g^s and g^r; both compute g^(rs) = shared secret. **No authentication by itself** (S310)	اتفاق على سر مشترك عبر قناة علنية؛ لا يصادق الطرف الآخر وحده

2.3.6 تدريب: التشفير · Practice Cryptography

Q1. Which key does a sender use to create a digital signature?

A. receiver's public key
B. sender's private key
C. sender's public key
D. a shared secret key

Answer: B

Signature = hash encrypted with signer's private key; anyone verifies with the public key.

التوقيع بالمفتاح الخاص والتحقق بالعام.

Q2. RSA with p=3, q=11, e=3. What are n, φ(n) and d?

A. 33, 20, 7
B. 33, 20, 3
C. 14, 20, 7
D. 33, 30, 7

Answer: A

n=33, φ=2·10=20, d with 3d≡1 (mod 20) → d=7 (21=20+1).

n=33 وφ=20 وd=7 لأن 3×7=21≡1.

Q3. How many symmetric keys do 20 users need so every pair has a distinct key?

A. 40
B. 190
C. 380
D. 20

Answer: B

n(n−1)/2 = 20·19/2 = 190.

20×19/2 = 190.

Q4. Which is a symmetric block cipher with 128-bit blocks?

A. RSA
B. DES
C. AES
D. MD5

Answer: C

AES: 128-bit block; DES block is 64 bits; RSA is asymmetric; MD5 is a hash.

AES كتلته 128 بت.

Q5. Encrypt “ATTACK” with a Caesar shift of 3.

A. DWWDFN
B. DVVDFN
C. CWWCFN
D. DWWDEN

Answer: A

A→D, T→W, T→W, A→D, C→F, K→N.

.A→D, T→W, C→F, K→N

Q6. A hash is used mainly to ...

A. hide a message
B. detect changes to data
C. exchange keys
D. speed up encryption

Answer: B

Integrity check/seal.

لكشف أي تعديل (سلامة).

الفصل الثالث: البرامج والبرمجة ·
Chapter 3 — Programs & Programming

3.1 الخطأ والعيب والفشل وتصنيف العيوب · Error, Fault, Failure, Taxonomy

★★★ Essential · أساسي

Why programs? Almost everything in a computer is a program (OS, drivers, databases, even code on web pages), so **protecting programs is at the heart of computer security** (S321). Programs can fail in two ways for security: they can give **wrong results** (integrity) and they offer **opportunities for attackers**.

لماذا البرامج؟ لأن كل شيء تقريباً في الحاسوب برنامج (النظام، المشغّلات، قواعد البيانات، حتى شيفرة صفحات الويب)، لذلك **حماية البرامج في صميم أمن الحاسوب**. قد تؤذي البرامج أمنياً بنتائج خاطئة (سلامة) أو بإتاحة فرص للمهاجمين.

Term	Meaning (S323–S324)	Viewpoint	بالعربية
Error	a human mistake (e.g. misunderstanding a requirement)	—	خطأ بشري
Fault (bug/flaw)	incorrect step, command, process or data definition in a program/design/documentation caused by an error	**inside view** (developer's eyes)	عيب داخلي
Failure	a departure from the system's required behaviour; can be discovered before or after delivery: during **testing** or during **operation & maintenance**	**outside view** (user's view)	فشل ظاهر للمستخدم

Analogy · تشبيه

Error (the cook mis-reads the recipe) → fault (too much salt written in the dish's recipe) → failure (the guest tastes the salty soup).

الخطأ: الطباخ يقرأ الوصفة خطأً. العيب: كمية الملح الزائدة في الوصفة. الفشل: الضيف يتذوق الحساء المالح.

MCQ pack (2015-16 & 2016-17 & 2018-19)

"The error may lead to a ..." → fault ("an incorrect step, command" **and** "process and data definition" → a & b). "A failure is ... of the system" → **outside view** and user view (b & c). "A failure can be discovered ..." → testing **or** operation/maintenance (a or b). "A bug can be a mistake in ..." → **all true** (interpreting a requirement, a syntax error, the cause of a crash). "Unexpected behaviour of the code" → **program security flaw**.

أسئلة: الخطأ يقود إلى عيب (fault). الفشل = منظور خارجي/مستخدم. الفشل يُكتشف أثناء الاختبار أو التشغيل والصيانة. Bug يشمل كل الاحتمالات. السلوك غير المتوقع = Program security flaw.

Landwehr taxonomy of program flaws (S325) ★★★

Branch	Sub-categories	Key phrase to remember	بالعربية
Intentional flaws	**malicious** (e.g. Trojan horse, virus, trapdoor, logic/time bomb) and **nonmalicious**	written on purpose	مقصودة: خبيثة وغير خبيثة
Inadvertent flaws	1) **Validation error** (incomplete/inconsistent) → *permission checks* 2) **Domain error** → *controlled access to data* 3) **Serialization and aliasing** → *program flow order* 4) **Inadequate identification and authentication** → *basis for authorization* 5) **Boundary condition violation** → *failure on first or last case* 6) **Other exploitable logic errors**	each category is linked with a short phrase (shown in italics) — the exam MCQ gives the phrase and asks for the category	غير مقصودة: 6 فئات بالترتيب المذكور

Exam: "What is the taxonomy of program flaws and the categories of each?" (2016-17 Q7(2nd), 2018-19 Q4)

Draw a tree: Program flaws → Intentional (Malicious / Nonmalicious) and Inadvertent (6 categories above) and write one line for each. MCQ 2015-16 Q22: serialization and aliasing ⇒ **program flow order**.

ارسم شجرة: عيوب البرامج ← مقصودة (خبيثة/غير خبيثة) وغير مقصودة (6 فئات) مع سطر شرح لكل فئة. سؤال MCQ: serialization & aliasing ← ترتيب تدفق البرنامج.

3.2 · فيض المخزن المؤقت وهفوات البرمجة الأخرى Buffer Overflows & Oversights

★★★ Essential · أساسي

Nonmalicious program errors (S326): buffer overflow, incomplete mediation, TOCTTOU, off-by-one, undocumented access point (trapdoor), integer overflow, unterminated null-terminated string, parameter length/type/number, unsafe utility, race condition, unsynchronized activity. A malicious attacker can exploit a nonmalicious flaw.

أخطاء البرمجة غير الخبيثة: فيض المخزن، الوساطة غير المكتملة، TOCTTOU، خطأ بواحد، نقطة وصول غير موثقة، فيض الأعداد الصحيحة، نص غير منتهٍ بمحرف null، معاملات خاطئة، أدوات غير آمنة، حالة السباق... ويمكن للمهاجم استغلال عيب غير خبيث.

Buffer = an allocated segment of memory (array/string). **Buffer overflow** = a program writes beyond the allocated buffer. Analogy: pouring 11 litres into a 10-litre bottle — the extra spills onto whatever is next to it. Example: `char sample[10]` has valid indexes 0–9; `sample[10]` is **out of bounds** (MCQ 265).

المخزن المؤقت (Buffer) قطعة ذاكرة مخصصة. **فيض المخزن**: كتابة تتجاوز حدودها. تشبيه: صبّ 11 لتراً في زجاجة 10 لترات فيسيل الباقي على ما بجوارها. المصفوفة sample[10] فهارسها 0–9 والفهرس 10 خارج الحدود.

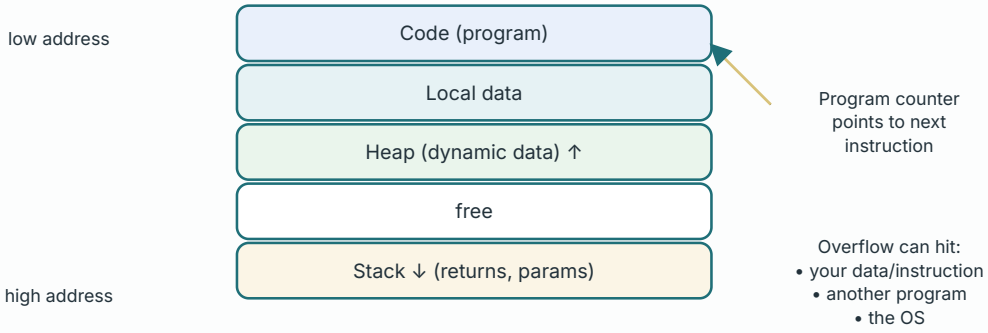


Figure (after Fig. 3-1): typical memory organisation — code, local data, heap, stack

Harm from an overflow (S332–S341)	بالعربية
Overwrite data/instructions next to the buffer (own program, another program's, or the OS's)	الكتابة فوق بيانات أو تعليمات مجاورة (لبرنامجك أو لغيرك أو النظام)
Overwrite **system code space** → privilege escalation (run attacker code with higher privileges)	الكتابة فوق شيفرة النظام ← رفع الصلاحيات
Overwrite the **return address / saved program counter** or old stack pointer on the **stack** → control jumps where the attacker wants	تغيير عنوان العودة في المكدس فيقفز التنفيذ لشيفرة المهاجم
Very long **URL parameters** sent to a web server (e.g. 1000-digit phone number)	معاملات URL طويلة جداً تُرسل للخادم

Countermeasures (S342–S345)

Check lengths before writing · check array subscripts · double-check boundary code (off-by-one) · accept only as many characters as can be handled · use bounded string utilities · limit program privileges · **code reviews & independent testing** · **safe languages** (Java, .NET, Perl, Python check bounds; C, C++, assembly do not) · **static code analyzers** · **separation** of code and data · a **canary** to detect stack corruption. Responsibility is shared by the **programmer, OS, compiler and hardware**.

تحقق من الأطوال قبل الكتابة وحدود المصفوفات، وقيّد الصلاحيات، واستخدم لغات تفحص الحدود، والمحللات الساكنة، والفصل بين الشيفرة والبيانات، و«الكناري» لكشف تلف المكدس. المسؤولية مشتركة بين المبرمج ونظام التشغيل والمترجم والعتاد.

Oversight	What it is	بالعربية
Off-by-one error	a boundary/count is one greater or one less than intended	خطأ بواحد في الحد/العدّاد
Integer overflow	an arithmetic result exceeds the representable range	تجاوز مدى العدد الصحيح
Unterminated null-terminated string	string lacks its null terminator, so operations run on into memory	نص بلا محرف الإنهاء null

3.3 الوساطة غير المكتملة و TOCTTOU والأبواب الخلفية · Mediation, TOCTTOU, Trapdoors

★★★ Essential · أساسي

Mediation = checking that a subject is authorized before the operation. **Incomplete mediation** = the program accepts incorrect data or fails to check. Example: a shopping site puts `price=205` in the URL; the attacker edits it to `price=1` and buys cheaply. Fixes: **validate all input** (e.g. drop-down lists, range checks, impossible dates like 1800Feb30), never trust data held by the user — **"if data can be changed, assume they have been"** — and apply **complete mediation** via a reference monitor.

الوساطة (Mediation) = التحقق من تفويض الجهة قبل تنفيذ العملية. **الوساطة غير المكتملة** = قبول بيانات غير صحيحة أو عدم الفحص. مثال: موقع تسوق يضع السعر في الرابط فيعدّله المهاجم. الحل: التحقق من كل مُدخل، وعدم الوثوق ببيانات بيد المستخدم («إذا كان بالإمكان تغيير البيانات فافترض أنها تغيّرت»)، وتطبيق وساطة كاملة.

TOCTTOU = **T**ime-**O**f-**C**heck to **T**ime-**O**f-**U**se: a "bait and switch". The system checks permission, then something changes before it uses the result. Analogy: the guard checks your ticket, then you swap places with a person without a ticket before entering. It is a **synchronization/timing** problem (race condition) and can break confidentiality, integrity or both. **Countermeasures:** do not expose critical parameters during the lapse; the checking software owns the request data until the action is done; ensure **serial integrity** (no interruption during validation); copy the data to a protected area then validate the copy; **seal** the data to detect change.

TOCTTOU = الفاصل الزمني بين فحص الصلاحية واستخدام النتيجة، وفيه يتغير شيء يبطل الفحص (خدعة الاستبدال). مشكلة توقيت/تزامن (race condition) وتمسّ السرية أو السلامة أو كلتيهما. العلاج: عدم كشف المعاملات الحرجة، وامتلاك برنامج الفحص لبيانات الطلب حتى انتهاء الفعل، وضمان **serial integrity**، ونسخ البيانات لمنطقة محمية والتحقق من النسخة، وختم البيانات لكشف تعديلها.

Undocumented access point / trapdoor / backdoor: a hidden entry point to a module. Developers add it for testing or future hooks; it persists because they **forget to remove it**, leave it for testing/maintenance, or leave it as a **covert means of access**. Dangerous because it bypasses the normal access procedure.

الباب الخلفي (Backdoor/Trapdoor): مدخل غير موثّق في وحدة برمجية، يضعه المطوّر للاختبار أو للتوصيلات المستقبلية، ويبقى لأنه نسي إزالته أو تركه للصيانة أو كوسيلة وصول خفية. خطره أنه يتجاوز إجراءات الوصول الاعتيادية.

In the exam · في الاختبار

Careful: "A ... is/are nonmalicious program error(s)": **buffer overflow** ✔, **incomplete mediation** ✔, "security implication" (alternative overflow style via parameters) ✔. **Salami attack** and **Trojan horse** are malicious ✘.

انتبه: الأخطاء غير الخبيثة: فيض المخزن، الوساطة غير المكتملة. أما هجوم Salami وحصان طروادة فخبيثان.

3.4 الشيفرة الخبيثة · Malicious Code

★★★ Essential · أساسي

Malicious code (rogue program) = code planted by an agent with malicious intent to cause unanticipated or undesired effects. It can do anything any program can — or lie dormant until a **trigger**

(time/date, interval, event, condition, count, random).

الشيفرة الخبيثة: برنامج أو جزء برنامج زرعه شخص بنية خبيثة لإحداث آثار غير متوقعة. يمكنه فعل ما يفعله أي برنامج، أو الخمول حتى يقع **مشغّل** (وقت، حدث، شرط، عدد...).

Type	Defining feature (S365–S368)	Analogy	بالعربية
Virus	replicates by modifying other programs (attaches/embeds in them); **transient** (lives and dies with its host) or **resident** (stays in memory after host ends)	a germ that needs a host cell	فيروس يتكاثر بتعديل برامج أخرى
Worm	spreads copies of itself as a stand-alone program through a **network**	a self-propagating rumour	دودة تنتشر عبر الشبكات كبرنامج مستقل
Trojan horse	has a second, nonobvious malicious effect in addition to its primary (visible) effect	Greek wooden horse	حصان طروادة: وظيفة ظاهرة وأخرى خفية خبيثة
Logic bomb	"detonates" when a specified condition occurs; **time bomb** = trigger is a time/date	a bomb with a sensor	قنبلة منطقية تنفجر عند شرط معين
Trapdoor/backdoor	undocumented entry feature	secret door	باب خلفي
Rabbit	virus/worm that replicates without bound to exhaust a resource (e.g. fill the disk)	rabbits multiplying	أرنب: تكاثر بلا حدود لاستنزاف الموارد
Bot	a worm-like robot used in vast numbers (e.g. by search engines or botnets)	—	بوت
Ransomware	encrypts your data and demands payment for the key	kidnapper	فدية: تشفّر بياناتك وتطلب مالاً
Rootkit	conceals its own presence (and malicious activity) and tries to re-establish itself if removed (Sony XCP)	invisibility cloak	تخفٍ وبقاء
Keystroke logger	records keys pressed (all, or only for a given program)	hidden camera over your shoulder	مسجّل ضغطات المفاتيح

Common mistake · خطأ شائع

Virus vs worm: a virus modifies/attaches to other programs; a worm is a stand-alone program that spreads through networks. **Trojan** = hidden second effect (does not replicate by itself).

الفيروس يعدّل برامج أخرى ويلتصق بها، والدودة برنامج مستقل ينتشر عبر الشبكة، وحصان طروادة له أثر خفي ثانٍ ولا يتكاثر ذاتياً.

Exam: "What are the virus effects and how are they caused?" (2018-19 Q5) — S370–S372

Effect	How it is caused
Attach to executable program	modify file directory; write to executable program file
Attach to data or control file	modify directory; rewrite data; **append to data**; append data to itself
Remain in memory	intercept interrupt by modifying the interrupt-handler address table; load itself in non-transient memory
Infect disks	intercept interrupt; intercept OS call (e.g. format); modify system file; modify ordinary executable
Conceal itself	intercept system calls that would reveal it and falsify results; classify itself as "hidden" file
Spread infection	infect boot sector, systems program, ordinary program, or data read by programs to control execution
Prevent deactivation	activate before deactivating program and block deactivation; store a copy to reinfect after deactivation

اكتب الجدول: ماذا يفعل الفيروس (الالتصاق بالبرامج، بالبيانات، البقاء في الذاكرة، إصابة الأقراص، التخفي، نشر العدوى، منع الإيقاف) وكيف يحققه (تعديل الدليل، الكتابة في الملف، اعتراض المقاطعات، تعديل جدول عناوين المقاطعات، اعتراض نداءات النظام...).

Four aspects used to study malicious-code infections (S377): **Harm** (how it affects users and systems), **Transmission and propagation** (how it spreads and causes further spread), **Activation** (how it gains control and installs itself/ reactivates), **Stealth** (how it hides). "Authentication" is not one of them (MCQ 356).

الجوانب الأربعة: الضرر (Harm)، الانتقال والانتشار (Transmission & Propagation)، التنشيط (Activation)، التخفي (Stealth). المصادقة ليست منها.

3.5 الشيفرات الموجّهة والإجراءات المضادة · Targeted Code & Countermeasures

★★ Important · مهم

Attack/term (S373–S376)	Meaning	بالعربية
Phishing / **Vishing**	tricking people into revealing secrets by e-mail / by voice or phone; goal: steal money or credentials	التصيّد بالبريد / بالهاتف (Vishing)
Salami attack	accumulating many tiny unauthorized gains (e.g. rounding fractions of cents)	هجوم الشرائح: تجميع مكاسب صغيرة جداً
Privilege escalation	code launched by a low-privilege user runs with higher privileges	رفع الصلاحيات
Interface illusion	a spoofing attack in which all or part of a web page is false (fake buttons/pages)	وهم الواجهة: صفحة ويب مزيفة كلياً أو جزئياً
Man-in-the-middle	a malicious program interjects between two programs/parties and monitors/changes traffic	هجوم الرجل في الوسط
Timing attack	infers secrets from execution time (even tiny timing differences matter in cryptography)	هجوم التوقيت
Covert channel	hidden path that leaks information (programs that leak information)	قناة خفية لتسريب المعلومات

Countermeasures (S378–S389)

Users: awareness (company threat board, social-engineering training), **clean desk** & **clean screen** policies, password policy (strong, never reused), buy software from reliable vendors, **test new software on an isolated computer**, do not open suspicious attachments (even documents/media can carry code), keep anti-malware up to date, use **IDS & IPS** (IDS detects, IPS blocks), treat any web site as potentially harmful, keep a **recoverable system image** and **backups**, disaster recovery & business continuity. **Virus scanners** look for a **signature**/fingerprint — limit: only known patterns, so they need frequent updates. **Developers** (S388–S389): specify, design, implement, **test** (ensure the system meets the requirements and implements the design), review, document, manage and maintain the system — software engineering (SWE) practices.

للمستخدم: الوعي (لوحة التهديدات، التدريب على الهندسة الاجتماعية)، سياسة المكتب والشاشة النظيفين، سياسة كلمات المرور، برمجيات من مصادر موثوقة، تجربة البرامج الجديدة على جهاز معزول، الحذر من المرفقات، تحديث مضاد البرمجيات الخبيثة، IDS و IPS، نسخة نظام قابلة للاستعادة ونسخ احتياطية واستمرارية الأعمال. كاشفات الفيروسات تعتمد على التواقيع (حدّها: الأنماط المعروفة فقط). للمطوّر: التحديد والتصميم والتنفيذ والاختبار (التأكد من تحقيق المتطلبات والتصميم) والمراجعة والتوثيق والإدارة والصيانة.

SSDLC (Secure Software Development Life Cycle, S390): security requirements → security design → security development → security testing → security deployment → security maintenance (iterative). Early integration saves cost. **Security requirement types** (S393): identification, authentication, authorization, immunity, integrity, intrusion detection, non-repudiation, privacy, security auditing, survivability, physical protection, system-maintenance security. **Identification asks "who are you claiming to be?", authentication asks "can it be verified?", authorization asks "what may you do?"**

SSDLC: متطلبات الأمن ← تصميم ← تطوير ← اختبار ← نشر ← صيانة (تكراري). الدمج المبكر يوفّر التكلفة. من أنواع متطلبات الأمن: الهوية، المصادقة، التفويض، المناعة، السلامة، كشف التسلل، عدم الإنكار، الخصوصية، التدقيق، البقاء (Survivability)، الحماية المادية.

3.6 تدريب: الفصل الثالث · Practice Chapter 3

Q1. Which memory area stores procedure call and return information?

A. Heap
B. Stack
C. Code
D. Static data

Answer: B

The stack (return address, parameters).

المكدس يخزّن عنوان العودة والمعاملات.

Q2. A shopping page puts the price in the URL and the server trusts it. This is ...

A. buffer overflow
B. incomplete mediation
C. trapdoor
D. rootkit

Answer: B

Input not validated → incomplete mediation.

لم يُتحقق من المدخل فهي وساطة غير مكتملة.

Q3. The delay between checking permission and using it being exploited is ...

A. salami attack
B. TOCTTOU
C. phishing
D. covert channel

Answer: B

Time-of-check to time-of-use.

.TOCTTOU

Q4. Which malware spreads through networks as a stand-alone program?

A. Virus
B. Worm
C. Logic bomb
D. Trojan

Answer: B

Worm.

الدودة.

Q5. Which is NOT one of the four aspects of malicious-code infections?

A. Harm
B. Stealth
C. Activation
D. Authentication

Answer: D

Aspects: harm, transmission/propagation, activation, stealth.

المصادقة ليست من الجوانب.

Q6. A program that “detonates” on 1 January is a ...

A. time bomb
B. worm
C. rabbit
D. keylogger

Answer: A

A time bomb = logic bomb triggered by time/date.

قنبلة زمنية.

الأخطاء الشائعة وكيف تتجنبها · Common Mistakes

#	Mistake	Fix	المعالجة
1	Mixing up threat and vulnerability	Vulnerability = hole/weakness; threat = what could exploit it; control = protection	الثغرة ضعف، التهديد مستغل محتمل، الضابط حماية
2	Saying “identification = authentication”	Identification = claim, authentication = proof (identity is public, authentication is private)	الهوية ادعاء والمصادقة إثبات
3	Choosing “All of the above” without checking each option	Test every option; when two are right choose “a & b”; if one is wrong “all of the above” is wrong	افحص كل خيار على حدة
4	Swapping Interception/Interruption	Interception = *read* (confidentiality); Interruption = *unavailable* (availability)	Interception يمس السرية وInterruption يمس التوافر
5	ACL per subject / directory per object	ACL = per **object**; directory/capability list = per **subject**	ACL لكل كائن والدليل لكل موضوع
6	Believing two passwords = MFA	MFA needs **different categories** (know/have/are)	العوامل المتعددة من فئات مختلفة
7	Writing RSA with wrong keys	Encrypt with e: C=P^e mod n. Public={e,n}, Private={d,n}; d·e ≡ 1 mod φ(n), φ=(p−1)(q−1)	n=p·q وφ=(p−1)(q−1)
8	Forgetting “(MD5 = 128, SHA = 160)”	MD5 128-bit digest; SHA/SHS 160-bit; DES block 64, AES block 128	MD5=128, SHA=160
9	Calling virus and worm the same	Virus modifies other programs; worm is stand-alone and spreads over networks	الفيروس يعدّل برامج، الدودة مستقلة وتنتشر بالشبكة
10	Ignoring the figure requirement	Questions saying “draw” lose marks without a labelled figure: practise the figures in this guide	ارسم الشكل مع تسمية الأجزاء
11	Writing paragraphs for list questions	Use numbered points (the slides’ wording), 1 line each	اكتب نقاطاً مرقمة بعبارات الشرائح

Exam Question Map · خريطة أسئلة الاختبارات السابقة

Where each recurring past-exam question is taught in this guide:

أين يُشرح كل سؤال متكرر من الاختبارات السابقة في هذا الدليل:

Past-exam question (year)	Section	Type
CIA examples (2016-17 Q1, 2017-18 Q1, 2018-19 Q3)	1.3	Essay ★★★
Properties of failure of confidentiality (2016-17 Q2, 2017-18 Q2)	1.3	Essay ★★
Identification vs authentication (3 exams)	2.1	Essay ★★★
Password-guessing steps; criteria of good passwords (3 exams)	2.1.1	Essay ★★★
Biometrics advantages and problems (2016-17, 2018-19)	2.1.2	Essay ★★★
Federated identity management with figure (2016-17 Q3E)	2.1.2	Essay ★★
Vulnerability vs threat vs control (2016-17 Q4, 2017-18 Q4)	1.2	Essay ★★★
Reference-monitor access models; ACD vs ACL (2016-17 Q5)	2.2.1	Essay ★★★
Method, opportunity, motive (2016-17 Q6)	1.5	Essay ★★
Countermeasures + figure (2016-17 Q7, 2017-18 Q5); ways to deal with harm (2018-19 Q2)	1.7	Essay ★★★
AES (2016-17 Q8A, 2017-18 Q6A); RSA (3 exams); stream vs block (3 exams)	2.3.2–2.3.4	Essay ★★★
Taxonomy of program flaws (2016-17, 2018-19)	3.1	Essay ★★★
Virus effects (2018-19 Q5)	3.4	Essay ★★
Advantages of isolating components (2016-17 Q9)	legacy	see Legacy page
MCQ: threats/harm acts/CIA (Q16–19 style)	1.3–1.4	MCQ
MCQ: laws=procedural, power failure=natural, machinicide=hardware	1.5–1.7	MCQ
MCQ: authentication examples (fingerprint, badge, passphrase, voice, card+PIN)	2.1	MCQ
MCQ: MD5/SHA digest sizes; product cipher; stream/block advantages	2.3	MCQ
MCQ: ACL/Directory/Capability/ACM-sparse/least privilege	2.2	MCQ
MCQ: error/fault/failure; nonmalicious errors; serialization & aliasing; interface illusions	3.1–3.5	MCQ

مواضيع قديمة خارج شرائح 2026 · Legacy Topics

These appeared in 2015-16 (and some in 2018-19) but are **not in the 2026 slides**. Learn only if time remains. Answers are from general textbook knowledge and carry **moderate** confidence.

ظهرت في 2015-16 (وبعضها في 2018-19) لكنها **ليست في شرائح 2026**؛ ادرسها إن بقي وقت. الإجابات من المعرفة العامة للكتاب ودرجة ثقتها **متوسطة**.

Topic	Short answer	بالعربية
Separation kinds	**Physical** (different physical objects), **temporal** (different times), **logical** (illusion that no other processes exist), **cryptographic** (hide data/computations)	العزل: مادي، زمني، منطقي (وهم عدم وجود غيرك)، تشفيري
Fence / fence register	a fixed boundary separating OS from user memory; confines users to one side; does not protect users from each other	السياج: حدّ ثابت يفصل النظام عن المستخدم
Base/bounds registers	two registers per user give start and limit of its address space; works with two or more users	سجلات الأساس والحد لكل مستخدم
Tagged architecture	each memory word carries tag bits (data/code rights)	وسم لكل كلمة ذاكرة
Segmentation vs paging	segmentation = logical units, can protect separately; paging = fixed-size pages, offers **implementation efficiency** but the user cannot mark areas as inviolable	التجزئة وحدات منطقية، والتصفيح (Paging) كفاءة تنفيذية
Kerberos	authentication service using **tickets** issued by a KDC, protected with **symmetric** cryptography	تذاكر محمية بتشفير متماثل
Encapsulation / information hiding / modularity / coupling	Encapsulation: component isolated from others; Information hiding: developers cannot maliciously alter components whose workings they do not know; Modularity: split into components; Coupling: degree a component depends on others (low is good)	الاقتران: درجة اعتماد المكوّن على الآخرين (الأقل أفضل)

ورقة المراجعة السريعة · Rapid Review Sheet

Read this the night before and again in the morning. Everything in bold is exam-critical.

اقرأها ليلة الاختبار وصباحه. كل ما هو بخط عريض حاسم.

Chapter 1 · 1 الفصل

Fact	Remember
Definitions	**Vulnerability**=weakness · **Threat**=could exploit · **Control**=removes/reduces vulnerability · **Incident**=V+T · **Risk**=possibility of harm · **Residual risk**=left after controls
CIA	C: read-only by authorized · I: modify only by authorized · A: usable when needed · plus authentication, nonrepudiation, auditability, privacy (4th leg)
4 harm acts	Interception→C · Interruption→A · Modification→I · Fabrication→authenticity/I
Attacks	Passive: snooping, traffic analysis (C) · Active: masquerade, replay, modification, repudiation, DoS (I, A, authenticity)
Threat types	nonhuman · human benign · human malicious · external vs internal (≈80% internal)
MOM	Method=how · Opportunity=when · Motive=why · deny one ⇒ attack fails
6 ways	Prevent · Deter · Deflect · Mitigate · Detect · Recover
3 control classes	Physical · Procedural/Administrative (laws, policies) · Technical (passwords, firewall, encryption)
Classification	business: Public/Sensitive/Private/Confidential · military: Unclassified/Confidential/Secret/Top Secret · TLP: White/Green/Amber/Red
CVE vs CVSS	list/dictionary vs severity score · APT: advanced, persistent, silent, spear phishing

Chapter 2 · 2 الفصل

Fact	Remember
Authentication	Identification (claim) → Authentication (proof) → Authorization → Accounting · factors: know / have / are (+do)
Password	difficulties: Use, Disclosure, Revocation, Loss · defences: hash (one-way), salt, lockout · attacks: dictionary, inference, guessing, defeating concealment (rainbow tables), brute force
Biometrics	pros: cannot be lost/stolen/forgotten/shared · cons: cost, intrusive, not exact, false positive/false negative, single point of failure
Tokens	passive/active · static/dynamic (SecurID) · skimming · federated identity/SSO · MFA = different categories
Access control	DAC (owner) · MAC (labels) · RBAC (roles) · ABAC (attributes) · reference monitor: always invoked, tamperproof, verifiable
Structures	ACD per subject · ACL per object · matrix sparse · capability = unforgeable ticket created by OS · least privilege
Crypto basics	plaintext/ciphertext/key · symmetric n(n−1)/2 keys vs asymmetric 2n · confusion=substitution, diffusion=transposition

Stream vs block	stream: fast, low error propagation, low diffusion · block: high diffusion, immune to insertion, slower, padding, error propagation
DES vs AES	DES 64-bit block, 56-bit key, 16 rounds · AES 128-bit block, 128/192/256 key, 10/12/14 rounds; SubBytes, ShiftRows, MixColumns, AddRoundKey
RSA	p=17 q=11 → n=187 φ=160 e=7 d=23 · PU={7,187} PR={23,187} · M=88 → C=11
Hash/Signature	MD5=128-bit · SHA=160-bit · signature = hash encrypted with signer's private key · CA signs certificate binding identity to public key · Diffie–Hellman = shared secret, no authentication

Chapter 3 · الفصل 3

Fact	Remember
Terms	Error (human) → Fault (inside view) → Failure (outside view; found in testing or operation)
Taxonomy	Intentional (malicious / nonmalicious) · Inadvertent: validation error, domain error, serialization & aliasing, inadequate I&A, boundary-condition violation, other logic errors
Buffer overflow	write past the buffer; stack (return address) vs heap; countermeasures: bound checks, safe languages, static analyzers, canary, least privilege
Mediation	incomplete mediation = unvalidated input (price in URL) · complete mediation via reference monitor · TOCTTOU = time gap check→use
Trapdoor	undocumented entry; left because forgotten/for maintenance/covert
Malware	virus (modifies programs; transient/resident) · worm (network, stand-alone) · Trojan (hidden second effect) · logic/time bomb · rabbit · ransomware · rootkit (stealth) · keylogger
4 aspects	Harm · Transmission & propagation · Activation · Stealth
Other attacks	phishing, vishing, salami, privilege escalation, interface illusion, MITM, timing, covert channel
Defence	clean desk/screen, password policy, antimalware (signatures), IDS (detect) vs IPS (block), backups, SSDLC (6 phases)

Priority Ranking · ترتيب الأولويات: الأساسي مقابل الثانوي

Rank	Topic	Why	Study time
★★★	Authentication essays (compare, 12 steps, good passwords, biometrics)	3/3 exams	60 min
★★★	CIA examples + harm acts; Vulnerability/Threat/Control; countermeasures & figure	3/3 and 2/3 exams	60 min
★★★	RSA (+ worked example), stream vs block, AES	3/3, 3/3, 2/3 exams	60 min
★★★	Access control: ACL/ACD/capability/matrix + models	MCQ repeats + essay	45 min
★★★	Program flaws: error/fault/failure, taxonomy, buffer overflow, mediation, TOCTTOU	MCQ + essay 2/3	45 min
★★	Malware types + virus effects + four aspects + countermeasures	essay once + new MCQ bank	30 min
★★	Classical ciphers, DES, hashes, signatures, certificates, DH	new MCQ bank	30 min
★★	Classification, layers, CVE/CVSS, APT, attackers	new MCQ bank	20 min
★	SSDLC, security requirements, tools list	new MCQ bank only	10 min
★ legacy	OS memory protection, Kerberos, maturity, compensating control	2015-16 only	skip unless time

Final advice · نصيحة أخيرة

You do not need to memorise pages — you need the **lists** (12 steps, 6 ways, 4 acts, 6 flaw categories, 7 RSA steps, 4 AES steps) and one example per concept. Sleep matters more than the last extra hour.

أنت لا تحتاج حفظ الصفحات بل **القوائم** (12 خطوة، 6 طرق، 4 أفعال، 6 فئات عيوب، 7 خطوات RSA، 4 خطوات AES) ومثالاً لكل مفهوم. النوم الكافي أهم من ساعة إضافية في آخر الليل.